



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services



دبلوم امن المعلومات

الفصل الثاني: التشريعات والقوانين المرتبطة بأمن المعلومات



دبلوم امن المعلومات

اسم المقرر:	السياسات والتشريعات والاخلاقيات والالتزام بها
رمز المقرر:	ISE123
الموضوع:	الفصل الثاني: التشريعات والقوانين المرتبطة بأمن المعلومات



يُميز بين حماية البيانات الشخصية ومكافحة الجرائم الإلكترونية في سياق مؤسسي.

يشرح دور الإطار القانوني في حماية البيانات والمعلومات. 

يحلل مسؤولية الموظف والمنظمة في سيناريو معالجة بيانات غير منضبطة. 

يقارن متطلبات خصوصية البيانات في النظام السعودي واللائحة العامة لحماية البيانات على مستوى المفهوم. 

يقترح استجابة تنظيمية أولية لمخالفة قانونية محتملة. 



خريطة الفصل

ينتظم الفصل في أربعة محاور مترابطة.

CHAPTER MAP · FOUR AXES

خريطة الفصل

04

المسؤوليات

الإبلاغ والتصعيد
القانوني

أثر التنظيم في التصميم

03

الأنظمة السعودية

واللائحة العامة

GDPR

02

البيانات الشخصية

خصوصية البيانات
ومعالجتها

01

الإطار القانوني

حماية المعلومات
نقطة انطلاق الفصل

ينتظم الفصل في أربعة محاور مترابطة تنتهي بأثر المتطلبات التنظيمية في تصميم الخدمات الرقمية.



- ◀ يتوزع التعلم المخطط على ست وحدات غير متزامنة، مدة كل وحدة 70 دقيقة.
- ◀ تدرس الوحدة الأولى الإطار القانوني وحماية المعلومات، والثانية معالجة البيانات والغرض وتقليل البيانات، والثالثة المسؤوليات وسجل المعالجة، والرابعة الواقعة والإفصاح والأدلة، والخامسة المقارنة والخصوصية، والسادسة التصميم التنظيمي والواجب ومرحلة المشروع.
- ◀ تتضمن كل وحدة قراءة موجهة ونشاطاً ومخرجاً واضحاً.



خطة الوحدة الزمنية (تابع)



الوحدة	دراسة المحتوى	النشاط	التقييم	المشروع	المجموع
الأولى	50 دقيقة	15 دقيقة	5 دقائق	،	70 دقيقة
الثانية	45 دقيقة	20 دقيقة	5 دقائق	،	70 دقيقة
الثالثة	40 دقيقة	15 دقيقة	15 دقيقة	،	70 دقيقة
الرابعة	40 دقيقة	15 دقيقة	15 دقيقة	،	70 دقيقة
الخامسة	45 دقيقة	15 دقيقة	10 دقائق	،	70 دقيقة
السادسة	25 دقيقة	،	5 دقائق	40 دقيقة	70 دقيقة



الإطار القانوني (Legal Framework)

- ◀ الإطار القانوني هو مجموعة الأنظمة واللوائح والمتطلبات التي تنظم معالجة البيانات وحمايتها والتعامل مع الجرائم المعلوماتية.
- ◀ وظيفته تحديد الحقوق والالتزامات والمسؤوليات ومسارات التعامل مع الوقائع ذات الصلة داخل المؤسسة.
- ◀ تميز المؤسسة بين النص النظامي أو اللائحة الواجبة التطبيق وبين المعيار أو الإطار الإرشادي الذي يدعم الحوكمة ولا يحل محل النظام أو الرأي القانوني المختص.
- ◀ **الوظيفة:** ضبط القرارات التنظيمية وحماية الحقوق.
- ◀ **المسؤوليات:** معرفة الأنظمة ذات الصلة، تنظيم المعالجة، حفظ السجلات اللازمة، تصعيد الحالات، طلب الاستشارة القانونية.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، نظام مكافحة جرائم المعلوماتية، NIST CSF 2.0، ISO/IEC 27001، GDPR.
- ◀ **الأجهزة أو الأدوات:** سجل معالجة بيانات، سياسة خصوصية، نموذج بلاغ داخلي، سجل احتفاظ، مصفوفة متطلبات.
- ◀ وحدة البيانات أو المخرج: سجل التزامات أو قرار تصعيد.
- ◀ **مثال:** توثق الشركة غرض خدمة الحجز ومالك معالجة بيانات المستخدمين.



الإطار القانوني (Legal Framework) (الشكل)

SLIDE 5 · LEGAL FRAMEWORK

الإطار القانوني



الأجهزة والأدوات

- سجل معالجة بيانات
- سياسة خصوصية
- نموذج بلاغ داخلي
- سجل احتفاظ
- مصفوفة متطلبات

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- نظام مكافحة جرائم المعلوماتية
- GDPR
- ISO/IEC 27001
- NIST CSF 2.0

الوظائف الرئيسية

- ضبط القرارات التنظيمية وحماية الحقوق
- معرفة الأنظمة ذات الصلة
- تنظيم المعالجة
- حفظ السجلات اللازمة
- تصعيد الحالات

توثق الشركة غرض خدمة الحجز ومالك معالجة بيانات المستخدمين

الإطار القانوني هو مجموعة الأنظمة واللوائح والمتطلبات التي تنظم معالجة البيانات وحمايتها والتعامل مع الجرائم المعلوماتية.



حماية المعلومات (Information Protection)



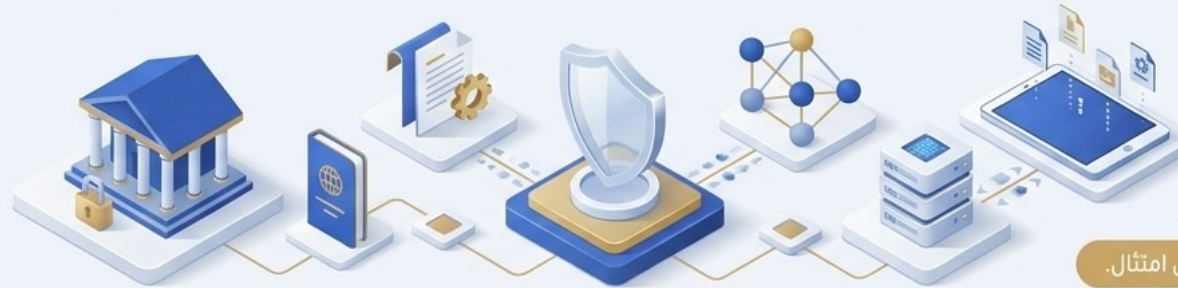
- ◀ حماية المعلومات هي ممارسات ونظم لإدارة المخاطر المرتبطة بالبيانات والأصول المعلوماتية.
- ◀ ولا تقتصر على أداة تقنية، بل تشمل الحوكمة والسياسات والضوابط والسجلات.
- ◀ وظيفتها إنشاء نظام إدارة أمن المعلومات وتحسينه بصورة مستمرة.
- ◀ فعند حماية سجل درجات، تجمع الشركة بين تحديد مالك السجل وضبط الوصول ومراجعة سجل النشاط، بدلاً من الاعتماد على حماية تقنية منفردة.
- ◀ **الوظيفة:** إدارة مخاطر أمن المعلومات.
- ◀ **المسؤوليات:** تحديد الأصول والبيانات، تطبيق ضوابط مناسبة، توثيق الإجراءات، متابعة التحسين، ربط الأمن بالحوكمة.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001:2022، ISO/IEC 27002:2022، NIST CSF 2.0.
- ◀ **الأجهزة أو الأدوات:** نظام إدارة أمن المعلومات، ضوابط أمنية، سجلات امتثال.
- ◀ وحدة البيانات أو المخرج: قرار معالجة مخاطر أو دليل امتثال.
- ◀ **مثال:** تربط الشركة سياسة حماية البيانات بسجل مراجعة الوصول.

(الشكل) (Information Protection) حماية المعلومات

SLIDE 6 · INFORMATION PROTECTION

حماية المعلومات

حماية المعلومات هي ممارسات ونظم لإدارة المخاطر المرتبطة بالبيانات والأصول المعلوماتية. ولا تقتصر على أداة تقنية، بل تشمل الحوكمة والسياسات والضوابط والسجلات. وظيفتها إنشاء نظام إدارة أمن المعلومات وتحسينه بصورة مستمرة.



الأجهزة والأدوات

- نظام إدارة أمن المعلومات
- ضوابط أمنية
- سجلات امتثال

البروتوكولات والمعايير

- ISO/IEC 27001:2022
- ISO/IEC 27002:2022
- NIST CSF 2.0

الوظائف الرئيسية

- إدارة مخاطر أمن المعلومات
- تحديد الأصول والبيانات
- تطبيق ضوابط مناسبة
- توثيق الإجراءات
- متابعة التحسين

تربط الشركة سياسة حماية البيانات بسجل مراجعة الوصول.

حماية المعلومات هي ممارسات ونظم لإدارة المخاطر المرتبطة بالبيانات والأصول المعلوماتية. ولا تقتصر على أداة تقنية، بل تشمل الحوكمة والسياسات والضوابط والسجلات.



- ◀ البيانات الشخصية هي موضوع الحماية في نظام حماية البيانات الشخصية السعودي، كما ترتبط بمعالجة بيانات الشخص الطبيعي في اللائحة العامة لحماية البيانات.
- ◀ وظيفتها التعليمية هنا تحديد ما يجب أن تنظمه المؤسسة عند جمع بيانات المستخدمين واستخدامها.
- ◀ لذلك لا يكفي أن تعرف الشركة أسماء الحقول، بل توثق سبب جمع كل حقل ومالك معالجته ومسار مشاركته ومدة الاحتفاظ به.
- ◀ **الوظيفة:** تمثل محل الالتزامات المتعلقة بالمعالجة والخصوصية.
- ◀ **المسؤوليات:** جمع البيانات بمسوغ مناسب، تحديد الغرض، تعيين جهة التحكم، تنظيم الإفصاح، متابعة الالتزام.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، لائحته التنفيذية، GDPR.
- ◀ **الأجهزة أو الأدوات:** سجل معالجة البيانات، سياسة الخصوصية، نموذج بلاغ داخلي.
- ◀ وحدة البيانات أو المخرج: سجل يبين النوع والغرض والمالك وفترة الاحتفاظ.
- ◀ **مثال:** تسجل الشركة اسم المستفيد ورقم جواله وبريده لخدمة حجز رقمية.



البيانات الشخصية (Personal Data) (الشكل)

SLIDE 7 · PERSONAL DATA

البيانات الشخصية



الأجهزة والأدوات

- سجل معالجة البيانات
- سياسة الخصوصية
- نموذج بلاغ داخلي

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- لائحته التنفيذية
- GDPR

الوظائف الرئيسية

- تمثل محل الالتزامات المتعلقة بالمعالجة والخصوصية
- جمع البيانات بمسوغ مناسب
- تحديد الغرض
- تعيين جهة التحكم
- تنظيم الإفصاح

تسجل الشركة اسم المستفيد ورقم جواله وبريده لخدمة حجز رقمية
البيانات الشخصية هي موضوع الحماية في نظام حماية البيانات الشخصية السعودي، كما ترتبط بمعالجة بيانات الشخص الطبيعي في اللائحة العامة لحماية البيانات.



- ◀ خصوصية البيانات مجال تنظيمي يتعلق بحماية الأشخاص الطبيعيين عند معالجة بياناتهم الشخصية.
- ◀ وهي تتقاطع مع أمن المعلومات، لكنها ليست مرادفة له، لأن أمن المعلومات منظومة أوسع لإدارة المخاطر.
- ◀ **الوظيفة:** تنظيم تعامل الجهة مع البيانات الشخصية وحقوق أصحابها.
- ◀ **المسؤوليات:** تحديد الغرض، تنظيم الإفصاح، إدارة الأدوار، حفظ السجلات، الاستجابة للحوادث.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، ISO/IEC 27002، ISO/IEC 27001، GDPR.
- ◀ **الأجهزة أو الأدوات:** سياسة خصوصية، سجل معالجة، سجل بلاغ، ضوابط وصول.
- ◀ وحدة البيانات أو المخرج: إشعار خصوصية أو قرار إفصاح موثق.
- ◀ **مثال:** تراجع الشركة حقول نموذج الحجز للتأكد من ارتباطها بالخدمة المطلوبة.



خصوصية البيانات (Data Privacy) (الشكل)

SLIDE 8 · DATA PRIVACY

خصوصية البيانات



الأجهزة والأدوات

- سياسة خصوصية
- سجل معالجة
- سجل بلاغ
- ضوابط وصول

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- GDPR
- ISO/IEC 27001
- ISO/IEC 27002

الوظائف الرئيسية

- تنظيم تعامل الجهة مع البيانات الشخصية وحقوق أصحابها
- تحديد الغرض
- تنظيم الإفصاح
- إدارة الأدوار
- حفظ السجلات

تراجع الشركة حقول نموذج الحجز للتأكد من ارتباطها بالخدمة المطلوبة

خصوصية البيانات مجال تنظيمي يتعلق بحماية الأشخاص الطبيعيين عند معالجة بياناتهم الشخصية



- ◀ معالجة البيانات الشخصية تشمل العمليات التي تجري على البيانات الشخصية، مثل جمعها أو حفظها أو استخدامها أو الإفصاح عنها أو إتلافها.
- ◀ وتنظم المؤسسة هذه العمليات بتحديد الغرض والأدوار والسجلات، لكن غياب التوثيق لا يعني أن العملية ليست معالجة.
- ◀ وتعرّف اللائحة العامة لحماية البيانات جهة التحكم بأنها الجهة التي تحدد أغراض المعالجة ووسائلها.
- ◀ **الوظيفة:** تنفيذ غرض محدد من التعامل مع البيانات الشخصية.
- ◀ **المسؤوليات:** تعيين الجهة المسؤولة، توثيق الغرض، تحديد البيانات، ضبط الإفصاح، متابعة الالتزام.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، اللائحة التنفيذية، GDPR.
- ◀ **الأجهزة أو الأدوات:** سجل معالجة بيانات، نموذج موافقة عند الاقتضاء، سياسة خصوصية.
- ◀ وحدة البيانات أو المخرج: سجل معالجة موثق.
- ◀ **مثال:** تستخدم الشركة بيانات الاتصال لإرسال تحديث متعلق بطلب خدمة قدمه المستخدم.



معالجة البيانات الشخصية (Personal Data Processing) (الشكل)

SLIDE 9 • PERSONAL DATA PROCESSING

معالجة البيانات الشخصية



الأجهزة والأدوات

- سجل معالجة بيانات
- نموذج موافقة عند الاقتضاء
- سياسة خصوصية

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- اللائحة التنفيذية
- GDPR

الوظائف الرئيسية

- تنفيذ غرض محدد من التعامل مع البيانات الشخصية
- تعيين الجهة المسؤولة
- توثيق الغرض
- تحديد البيانات
- ضبط الإفصاح

تستخدم الشركة بيانات الاتصال لإرسال تحديث متعلق بطلب خدمة قدمه المستفيد
معالجة البيانات الشخصية تشمل العمليات التي تجري على البيانات الشخصية، مثل جمعها أو حفظها أو استخدامها أو الإفصاح عنها أو إتلافها



الغرض المحدد للمعالجة (Specified Purpose)

- ◀ الغرض المحدد للمعالجة هو غاية معلنة ترتبط بها البيانات التي تجمعها المؤسسة وتستخدمها.
- ◀ وهو يضبط قرار الجمع والاستخدام، ويمنع التوسع في استعمال البيانات دون مبرر تنظيمي موثق.
- ◀ يراجع مالك الخدمة الغرض عند تعديل النموذج أو إضافة جهة مشاركة أو اقتراح استخدام جديد، ثم يوثق القرار في سجل المعالجة وإشعار الخصوصية ذي الصلة.
- ◀ **الوظيفة:** ربط البيانات بغرض مشروع وقابل للمراجعة.
- ◀ **المسؤوليات:** توثيق الغرض، ربط البيانات بالخدمة، مراجعة تغيير الغرض، إشراك المختص عند الحاجة، تحديث السجل والسياسة.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، دليله الإرشادي، GDPR.
- ◀ **الأجهزة أو الأدوات:** سجل معالجة بيانات، نموذج خدمة، إشعار خصوصية.
- ◀ وحدة البيانات أو المخرج: بيان غرض معالجة قابل للمراجعة.
- ◀ **مثال:** يجمع رقم الجوال لتأكيد موعد خدمة، لا لاستخدام تسويقي غير مرتبط بالخدمة.



الغرض المحدد للمعالجة (Specified Purpose) (الشكل)

SLIDE 10 • SPECIFIED PURPOSE

الغرض المحدد للمعالجة



الأجهزة والأدوات

- سجل معالجة بيانات
- نموذج خدمة
- إشعار خصوصية

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- دليله الإرشادي
- GDPR

الوظائف الرئيسية

- ربط البيانات بغرض مشروع وقابل للمراجعة
- توثيق الغرض
- ربط البيانات بالخدمة
- مراجعة تغيير الغرض
- إشراك المختص عند الحاجة

يجمع رقم الجوال لتأكيد موعد خدمة، لا للاستخدام تسويقي غير مرتبط بالخدمة.

الغرض المحدد للمعالجة هو غاية معلنة ترتبط بها البيانات التي تجمعها المؤسسة وتستخدمها.



تقليل البيانات (Data Minimization)

- ◀ تقليل البيانات منهج تنظيمي يقصر البيانات المجمعة والمحفوطة على ما يلزم للغرض المحدد.
- ◀ وهو يقلل التعرض التنظيمي والأمني الناتج عن الاحتفاظ ببيانات لا تحتاجها الخدمة.
- ◀ وتطبق الشركة المنهج بمراجعة كل حقل في النموذج: ما علاقته بالخدمة، ومن يحتاجه، وكم مدة الاحتفاظ به.
- ◀ فإذا غاب المبرر، يحذف الحقل أو يحال القرار للمختص.
- ◀ **الوظيفة:** خفض مخاطر البيانات غير اللازمة.
- ◀ **المسؤوليات:** مراجعة حقول الجمع، إزالة الحقول غير اللازمة، تحديد الاحتفاظ، مراجعة النماذج، توثيق المبرر.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، ISO/IEC 27001، GDPR.
- ◀ **الأجهزة أو الأدوات:** قائمة حقول، سجل معالجة، نموذج مراجعة تصميم خدمة.
- ◀ وحدة البيانات أو المخرج: قائمة بيانات مبررة بحسب الغرض.
- ◀ **مثال:** لا تطلب الشركة وثيقة هوية إذا كان البريد الإلكتروني ورقم الطلب يكفيان لمعالجة طلب الدعم.



تقليل البيانات (Data Minimization) (الشكل)

SLIDE 11 • DATA MINIMIZATION

تقليل البيانات



الأجهزة والأدوات

- قائمة حقوق
- سجل معالجة
- نموذج مراجعة تصميم خدمة

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- GDPR
- ISO/IEC 27001

الوظائف الرئيسية

- خفض مخاطر البيانات غير اللازمة
- مراجعة حقوق الجمع
- إزالة الحقوق غير اللازمة
- تحديد الاحتفاظ
- مراجعة النماذج

لا تطلب الشركة وثيقة هوية إذا كان البريد الإلكتروني ورقم الطلب يكفيان لمعالجة طلب الدعم.

تقليل البيانات منهج تنظيمي يقصر البيانات المجمعة والمحفوطة على ما يلزم للغرض المحدد.



نشاط تطبيقي، مراجعة حقول نموذج الحجز



- ◀ لدى الشركة نموذج حجز يطلب الاسم ورقم الجوال والبريد الإلكتروني ونوع الخدمة وتاريخ الحجز ونسخة من وثيقة الهوية.
- ◀ صنف كل حقل إلى «لازم مباشرة للخدمة» أو «يحتاج مبرراً إضافياً»، ثم اكتب سبباً مختصراً للتصنيف.
- ◀ استخدم مبدأ الغرض المحدد وتقليل البيانات، واجعل مخرجك قائمة حقول مبررة قابلة للإضافة إلى سجل المعالجة.



- ◀ الاسم ورقم الجوال والبريد الإلكتروني ونوع الخدمة وتاريخ الحجز حقول لازمة مباشرة لتأكيد الحجز وإرسال تفاصيل الخدمة والدعم المرتبط بها.
- ◀ أما نسخة وثيقة الهوية فتحتاج مبرراً إضافياً محدداً قبل جمعها، لأن معطيات خدمة الحجز لا تبين ضرورتها.
- ◀ يثبت القرار في سجل المعالجة، ويراجع مالك الخدمة الحقول قبل اعتماد النموذج أو تعديله.

سجل معالجة البيانات الشخصية

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 · السجل التجاري: 1010000000
هاتف: 0500000000

المستند: سجل معالجة البيانات الشخصية

سجل معالجة البيانات الشخصية

Record of Processing Activities (ROPA) لخدمات المنصات التعليمية

نشاط المعالجة	الغرض المحدد	فئات البيانات الشخصية	صاحب البيانات	مالك المعالجة	المشاركة المصرح بها	فترة الاحتفاظ
إنشاء حساب المستخدم	تمكين المستخدم من الدخول إلى المنصة وإدارة طلباته	الاسم، رقم الجوال، البريد الإلكتروني، بيانات الدخول	المستخدم	إدارة المنصات التعليمية	فريق الدعم الفني المخول فقط	24 شهراً من آخر استخدام للحساب أو وفق مسوغ احتفاظ معتمد
حجز خدمة تعليمية رقمية	تأكيد الحجز وإرسال تفاصيل الخدمة والدعم المرتبط بها	الاسم، رقم الجوال، البريد الإلكتروني، نوع الخدمة، تاريخ الحجز	المستخدم	إدارة الخدمات الرقمية	فريق تشغيل الخدمة وفريق الدعم الفني	24 شهراً من تاريخ إتمام الخدمة
إصدار كشف درجات للمستخدم	عرض النتيجة الأكاديمية للمستخدم وتمكين الجهة التعليمية المخولة من متابعتها	الاسم، الرقم التعليمي الداخلي، المقرر، الدرجة، تاريخ النتيجة	المستخدم	إدارة المنصات التعليمية	الجهة التعليمية المخولة عبر القناة المعتمدة	حتى نهاية مدة الاحتفاظ الأكاديمي المعتمدة
معالجة طلب دعم فني	حل مشكلة تقنية مؤثرة مرتبطة بحساب المستخدم	الاسم، رقم الجوال، البريد الإلكتروني، وصف المشكلة، سجل التواصل	المستخدم	فريق الدعم الفني	فريق الدعم الفني فقط عند الحاجة	12 شهراً من إغلاق الطلب

هذا السجل نموذج تعليمي لتوثيق الغرض ونطاق البيانات والمسؤولية. لا يمثل تدقيقاً قانونياً أو سجلاً امتثالياً نهائياً.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

يقرأ المتعلم هذا السجل بوصفه دليلاً تنظيمياً يربط نشاط المعالجة بالغرض المحدد وفئات البيانات ومالك المعالجة.

في صف إنشاء الحساب، تظهر بيانات الاسم ورقم الجوال والبريد الإلكتروني وبيانات الدخول.

ويبين السجل أن مشاركة هذه البيانات تقتصر على فريق الدعم الفني المخول، مع احتفاظ محدد لمدة 24 شهراً من آخر استخدام للحساب أو وفق مسوغ احتفاظ معتمد.

مثال محلول على النموذج، بناء سجل معالجة بيانات

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

المستند: سجل معالجة البيانات الشخصية

سجل معالجة البيانات الشخصية

Record of Processing Activities (ROPA) لخدمات المنصات التعليمية

نشاط المعالجة	الغرض المحدد	فئات البيانات الشخصية	صاحب البيانات	مالك المعالجة	المشاركة المصرح بها	فترة الاحتفاظ

هذا السجل نموذج تعليمي لتوثيق الغرض ونطاق البيانات والمسؤولية. لا يمثل تدقيقاً قانونياً أو سجلاً آمثالياً نهائياً.
مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية.

- المعطيات: تقدم الشركة خدمة إنشاء حساب للمستخدمين وخدمة حجز تعليمية رقمية وخدمة إصدار كشف درجات وخدمة دعم فني.
- ويجب أن يسجل النموذج نشاط المعالجة، والغرض المحدد، وفئات البيانات، ومالك المعالجة، والمشاركة المصرح بها، وفترة الاحتفاظ.
- يبدأ التحليل بربط كل نشاط بالحد الأدنى من البيانات اللازمة لتقديم الخدمة المعتمدة.

الخطوة 1 من 4: توثيق إنشاء حساب المستخدم

شركة الحلول التقنية والخدمات الرقمية
إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
جازان، المملكة العربية السعودية
الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

المستند: سجل معالجة البيانات الشخصية

سجل معالجة البيانات الشخصية
Record of Processing Activities (ROPA) لخدمات المنصات التعليمية

نشاط المعالجة	الغرض المحدد	فئات البيانات الشخصية	صاحب البيانات	مالك المعالجة	المشاركة المصرح بها	فترة الاحتفاظ
إنشاء حساب المستخدم	تمكين المستخدم من الدخول إلى المنصة وإدارة طلباته	الاسم، رقم الجوال، البريد الإلكتروني، بيانات الدخول	المستخدم	إدارة المنصات التعليمية	فريق الدعم الفني المخول فقط	24 شهراً من آخر استخدام للحساب أو وفق مسوغ احتفاظ معتمد

هذا السجل نموذج تعليمي لتوثيق الغرض ونطاق البيانات والمسؤولية، لا يمثل تدقيقاً قانونياً أو سجلاً امتثالياً نهائياً.
مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية.

- يدوّن في الصف الأول نشاط إنشاء حساب المستخدم من معطيات المثال.
- الغرض المدون هو تمكين المستخدم من الدخول إلى المنصة وإدارة طلباته.
- تسجل البيانات اللازمة فقط، وهي الاسم ورقم الجوال والبريد الإلكتروني وبيانات الدخول.
- تطبق هنا قاعدة الغرض المحدد وتقليل البيانات.
- يحدد النموذج إدارة المنصات التعليمية مالِكاً للمعالجة، ويقصر المشاركة على فريق الدعم الفني المخول.
- النتيجة الجزئية هي توثيق غرض واضح وبيانات مرتبطة مباشرة بالخدمة.

الخطوة 2 من 4: توثيق حجز الخدمة التعليمية

المستند: سجل معالجة البيانات الشخصية

شركة الحلول التقنية والخدمات الرقمية
إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

سجل معالجة البيانات الشخصية
Record of Processing Activities (ROPA) لخدمات المنصات التعليمية

نشاط المعالجة	الغرض المحدد	فئات البيانات الشخصية	صاحب البيانات	مالك المعالجة	المشاركة المصرح بها	فترة الاحتفاظ
إنشاء حساب المستخدم	تمكين المستخدم من الدخول إلى المنصة وإدارة طلباته	الاسم، رقم الجوال، البريد الإلكتروني، بيانات الدخول	المستخدم	إدارة المنصات التعليمية	فريق الدعم الفني المخول فقط	24 شهراً من آخر استخدام للحساب أو وفق مسوغ احتفاظ معتمد
حجز خدمة تعليمية	تأكيد الحجز وإرسال تفاصيل الخدمة والدعم المرتبط بها	الاسم، رقم الجوال، البريد الإلكتروني، نوع الخدمة، تاريخ الحجز	المستخدم	إدارة الخدمات الرقمية	فريق تشغيل الخدمة وفريق الدعم الفني	24 شهراً من تاريخ إتمام الخدمة

هذا السجل نموذج تعليمي لتوثيق الغرض ونطاق البيانات والمسؤولية، لا يمثل تدقيقاً قانونياً أو سجلاً امتثالياً نهائياً.
مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية.

- ◀ يدوّن في الصف الثاني نشاط حجز خدمة تعليمية رقمية من معطيات المثال.
- ◀ الغرض هو تأكيد الحجز وإرسال تفاصيل الخدمة والدعم المرتبط بها.
- ◀ تسجل البيانات الآتية: الاسم ورقم الجوال والبريد الإلكتروني ونوع الخدمة وتاريخ الحجز.
- ◀ تطبق هنا قاعدة ربط فئات البيانات بالغرض المعلن.
- ◀ يحدد النموذج إدارة الخدمات الرقمية مالِكاً للمعالجة، ويصرح بالمشاركة لفريق تشغيل الخدمة وفريق الدعم الفني.
- ◀ النتيجة هي ربط الحجز ببيانات لازمة ومحددة.

الخطوة 3 من 4: توثيق إصدار كشف الدرجات

المستند: سجل معالجة البيانات الشخصية

شركة الحلول التقنية والخدمات الرقمية
إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستفيدين
جازان، المملكة العربية السعودية
الرقم الصريحي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

سجل معالجة البيانات الشخصية

Record of Processing Activities (ROPA) لخدمات المنصات التعليمية

نشاط المعالجة	الغرض المحدد	فئات البيانات الشخصية	صاحب البيانات	مالك المعالجة	المشاركة المصرح بها	فترة الاحتفاظ
إنشاء حساب المستفيد	تمكين المستفيد من الدخول إلى المنصة وإدارة طلباته	الاسم، رقم الجوال، البريد الإلكتروني، بيانات الدخول	المستفيد	إدارة المنصات التعليمية	فريق الدعم الفني المخول فقط	24 شهراً من آخر استخدام للحساب أو وفق مسوغ احتفاظ معتمد
حجز خدمة تعليمية	تأكيد الحجز وإرسال تفاصيل الخدمة والدعم المرتبط بها	الاسم، رقم الجوال، البريد الإلكتروني، نوع الخدمة، تاريخ الحجز	المستفيد	إدارة الخدمات الرقمية	فريق تشغيل الخدمة وفريق الدعم الفني	24 شهراً من تاريخ إتمام الخدمة
إصدار كشف درجات للمستفيد	عرض النتيجة الأكاديمية للمستفيد وتمكين الجهة التعليمية المخولة من متابعتها	الاسم، الرقم التعليمي الداخلي، المقرر، الدرجة، تاريخ النتيجة	المستفيد	إدارة المنصات التعليمية	الجهة التعليمية المخولة عبر القناة المعتمدة	حتى نهاية مدة الاحتفاظ الأكاديمي المعتمدة

هذا السجل نموذج تعليمي لتوثيق الغرض ونطاق البيانات والمسؤولية، لا يمثل تدقيقاً قانونياً أو سجلاً امتثالياً نهائياً.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- ◀ يدوّن في الصف الثالث نشاط إصدار كشف درجات للمستفيد من معطيات المثال.
- ◀ الغرض هو عرض النتيجة الأكاديمية وتمكين الجهة التعليمية المخولة من متابعتها.
- ◀ تشمل البيانات الاسم والرقم التعليمي الداخلي والمقرر والدرجة وتاريخ النتيجة.
- ◀ تطبق هنا قاعدة تحديد مالك المعالجة وقصر المشاركة على الجهة المخولة.
- ◀ مالك المعالجة هو إدارة المنصات التعليمية، والمشاركة مقصورة على الجهة التعليمية المخولة عبر القناة المعتمدة.
- ◀ النتيجة الجزئية هي تحديد بيانات أكاديمية تحتاج حماية ومسار مشاركة مضبوطاً.

الخطوة 4 من 4: توثيق طلب الدعم الفني

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
 جازان، المملكة العربية السعودية
 الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
 هاتف: 0500000000

المستند: سجل معالجة البيانات الشخصية

سجل معالجة البيانات الشخصية

Record of Processing Activities (ROPA) لخدمات المنصات التعليمية

نشاط المعالجة	الغرض المحدد	فئات البيانات الشخصية	صاحب البيانات	مالك المعالجة	المشاركة المصرح بها	فترة الاحتفاظ
إنشاء حساب المستخدم	تمكين المستخدم من الدخول إلى المنصة وإدارة طلباته	الاسم، رقم الجوال، البريد الإلكتروني، بيانات الدخول	المستخدم	إدارة المنصات التعليمية	فريق الدعم الفني المخول فقط	24 شهراً من آخر استخدام للحساب أو وفق مسوغ احتفاظ معتمد
حجز خدمة تعليمية	تأكيد الحجز وإرسال تفاصيل الخدمة والدعم المرتبط بها	الاسم، رقم الجوال، البريد الإلكتروني، نوع الخدمة، تاريخ الحجز	المستخدم	إدارة الخدمات الرقمية	فريق تشغيل الخدمة وفريق الدعم الفني	24 شهراً من تاريخ إتمام الخدمة
إصدار كشف درجات للمستخدم	عرض النتيجة الأكاديمية للمستخدم وتمكين الجهة التعليمية المخولة من متابعتها	الاسم، الرقم التعليمي الداخلي، المقرر، الدرجة، تاريخ النتيجة	المستخدم	إدارة المنصات التعليمية	الجهة التعليمية المخولة عبر القناة المعتمدة	حتى نهاية مدة الاحتفاظ الأكاديمي المعتمدة
معالجة طلب دعم فني	حل مشكلة تقنية موثقة مرتبطة بحساب المستخدم	الاسم، رقم الجوال، البريد الإلكتروني، وصف المشكلة، سجل التواصل	المستخدم	فريق الدعم الفني	فريق الدعم الفني فقط عند الحاجة	12 شهراً من إغلاق الطلب

هذا السجل نموذج تعليمي لتوثيق الغرض ونطاق البيانات والمسؤولية. لا يمثل تدقيقاً قانونياً أو سجلاً امتثالياً نهائياً.

مستند تعليمي إلكتروني، الأسماء والأرقام غير حقيقية

- ◀ يدوّن في الصف الرابع نشاط معالجة طلب دعم فني من معطيات المثال.
- ◀ الغرض هو حل مشكلة تقنية موثقة مرتبطة بحساب المستخدم.
- ◀ تشمل البيانات الاسم ورقم الجوال والبريد الإلكتروني ووصف المشكلة وسجل التواصل.
- ◀ تطبق هنا قاعدة توثيق الغرض ومالك المعالجة وفترة الاحتفاظ.
- ◀ يكون فريق الدعم الفني مالك المعالجة والمشارك المخول عند الحاجة، ويحدد النموذج الاحتفاظ لمدة 12 شهراً من إغلاق الطلب.
- ◀ النتيجة هي نموذج مكتمل يربط كل نشاط بغرض ومالك واحتفاظ واضحين.



شكل توضيحي، دورة حياة معالجة البيانات



- ◀ تمثل دورة حياة معالجة البيانات خمس مراحل مترابطة: الجمع، والمعالجة، والحفظ، والمشاركة، والإتلاف.
- ◀ تحيط بها مبادئ الغرض المحدد وتقليل البيانات وتحديد المسؤوليات وحفظ السجلات.
- ◀ في خدمة الحجز، يبدأ المسار بجمع بيانات الاتصال اللازمة، ثم يستخدمها لتأكيد الحجز، ويحفظها وفق المدة المعتمدة، ويقصر مشاركتها على فرق التشغيل والدعم المخولة، ثم يراجع قرار الإتلاف أو الاحتفاظ.



- ◀ مسؤولية المنظمة هي مسؤولية تنظيمية عن إدارة معالجة البيانات ومخاطر الأمن السيبراني عبر الحوكمة والسياسات والضوابط والسجلات.
- ◀ وهي تحول الالتزام من ممارسة فردية إلى عمل مؤسسي قابل للمتابعة.
- ◀ وتشمل توفير القنوات المعتمدة وتحديد الملاك والصلاحيات ومراجعة الأدلة، فلا يحمل الموظف وحده أثر قرار صممه المؤسسة أو قصرت في ضبطه.
- ◀ **الوظيفة:** بناء حوكمة قابلة للمراجعة والتحسين.
- ◀ **المسؤوليات:** تحديد جهة التحكم والأدوار، الإشراف على الالتزام، بناء السجلات، إدارة المخاطر، اتخاذ قرارات تصحيحية.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، ISO/IEC 27001، NIST CSF 2.0.
- ◀ **الأجهزة أو الأدوات:** سجل جهات التحكم، سياسة داخلية، مصفوفة مسؤوليات، سجل معالجة.
- ◀ وحدة البيانات أو المخرج: دليل التزام أو تقرير متابعة.
- ◀ **مثال:** تكلف الشركة مالك الخدمة بمتابعة سجل المعالجة مع فريق التقنية والشؤون القانونية.

(الشكل) (Organization Responsibility) مسؤولية المنظمة

SLIDE 18 · ORGANIZATION RESPONSIBILITY

مسؤولية المنظمة



الأجهزة والأدوات

- سجل جهات التحكم
- سياسة داخلية
- مصفوفة مسؤوليات
- سجل معالجة

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- ISO/IEC 27001
- NIST CSF 2.0

الوظائف الرئيسية

- بناء حوكمة قابلة للمراجعة والتحسين
- تحديد جهة التحكم والأدوار
- الإشراف على الالتزام
- بناء السجلات
- إدارة المخاطر

تكلف الشركة مالك الخدمة بمتابعة سجل المعالجة مع فريق التقنية والشؤون القانونية.

مسؤولية المنظمة هي مسؤولية تنظيمية عن إدارة معالجة البيانات ومخاطر الأمن السيبراني عبر الحوكمة والسياسات والضوابط والسجلات.



مسؤولية الموظف (Employee Responsibility)

- ◀ مسؤولية الموظف واجب مهني وتنظيمي عند التعامل مع البيانات والأنظمة ضمن الصلاحيات والسياسات الممنوحة.
- ◀ وجود وصول تقني إلى البيانات لا يمنح الموظف مشروعية مهنية أو نظامية لاستخدامها خارج غرض العمل.
- ◀ وعند الاشتباه في واقعة، يوثق الوقائع المتاحة ويحافظ على السجلات ويستخدم قناة البلاغ، ولا يقرر وحده التكييف القانوني أو الإفصاح الخارجي.
- ◀ **الوظيفة:** تقليل الإفصاح غير المنضبط والاستخدام خارج الصلاحية.
- ◀ **المسؤوليات:** الالتزام بالصلاحية، عدم مشاركة البيانات دون مسوغ، الإبلاغ الداخلي، حفظ السجلات، طلب التوجيه عند الشك.
- ◀ **البروتوكولات والمعايير:** نظام مكافحة جرائم المعلوماتية، سياسات المؤسسة، ISO/IEC 27002.
- ◀ **الأجهزة أو الأدوات:** سياسة استخدام، نظام بلاغات، سجل وصول، قناة تصعيد.
- ◀ وحدة البيانات أو المخرج: إقرار التزام أو سجل نشاط.
- ◀ **مثال:** يرفع موظف الدعم طلب تصعيد بدلاً من إرسال ملف عميل عبر قناة شخصية.



(الشكل) (Employee Responsibility) مسؤولية الموظف

SLIDE 19 · EMPLOYEE RESPONSIBILITY

مسؤولية الموظف



الأجهزة والأدوات

- سياسة استخدام
- نظام بلاغات
- سجل وصول
- قناة تصعيد

البروتوكولات والمعايير

- نظام مكافحة جرائم المعلوماتية
- سياسات المؤسسة
- ISO/IEC 27002

الوظائف الرئيسية

- تقليل الإفصاح غير المنضبط والاستخدام خارج الصلاحية
- الالتزام بالصلاحية
- عدم مشاركة البيانات دون مسوغ
- الإبلاغ الداخلي
- حفظ السجلات

يرفع موظف الدعم طلب تصعيد بدلاً من إرسال ملف عميل عبر قناة شخصية.

مسؤولية الموظف واجب مهني وتنظيمي عند التعامل مع البيانات والأنظمة ضمن الصلاحيات والسياسات الممنوحة.



- ◀ نظام حماية البيانات الشخصية نظام سعودي لحماية البيانات الشخصية، صدر بالمرسوم الملكي رقم (م/19) بتاريخ 9/2/1443هـ، وعُدل بالمرسوم الملكي رقم (م/148) بتاريخ 5/9/1444هـ.
- ◀ **الوظيفة:** تنظيم حماية البيانات والإشراف على الالتزام بأحكام النظام ولوائحه.
- ◀ **المسؤوليات:** مراعاة الأحكام واللوائح، تحديد جهة التحكم، متابعة الالتزام، إدارة التسجيل عند انطباق القواعد، تنظيم المعالجة.
- ◀ **البروتوكولات والمعايير:** النظام، اللائحة التنفيذية، قواعد السجل الوطني لجهات التحكم، لوائح نقل البيانات عند الصلة.
- ◀ **الأجهزة أو الأدوات:** منصة حوكمة البيانات الوطنية، السجل الوطني لجهات التحكم، سجل معالجة البيانات.
- ◀ وحدة البيانات أو المخرج: سجل معالجة أو وثيقة امتثال داخلية.
- ◀ **مثال:** تراجع الشركة بيانات الاتصال التي تجمعها وتوثق الغرض والمالك وفترة الاحتفاظ.



SLIDE 20 · ELEMENT

نظام حماية البيانات الشخصية



الأجهزة والأدوات

- منصة حوكمة البيانات الوطنية
- السجل الوطني لجهات التحكم
- سجل معالجة البيانات

البروتوكولات والمعايير

- النظام
- اللائحة التنفيذية
- قواعد السجل الوطني لجهات التحكم
- لوائح نقل البيانات عند الصلة

الوظائف الرئيسية

- تنظيم حماية البيانات والإشراف على الالتزام
- أحكام النظام ولوائحه
- مراعاة الأحكام واللوائح
- تحديد جهة التحكم
- متابعة الالتزام
- إدارة التسجيل عند انطباق القواعد

تراجع الشركة بيانات الاتصال التي تجمعها وتوثق الغرض والمالك وفترة الاحتفاظ.

نظام حماية البيانات الشخصية



- ◀ نظام مكافحة جرائم المعلوماتية نظام سعودي ساري، صدر بالمرسوم الملكي رقم (م/17) بتاريخ 8/3/1428هـ، الموافق 27/3/2007م. ويتضمن تعريفات وهدفاً وعقوبات لجرائم معلوماتية ومسؤولية الجهة التنظيمية الواردة في نبذة النظام.
- ◀ **الوظيفة:** تنظيم التعامل النظامي مع الأفعال غير المشروعة المرتبطة بالمعلوماتية.
- ◀ **المسؤوليات:** عدم ارتكاب الأفعال المحظورة، حفظ الأدلة والوقائع، التصعيد للجهات المختصة، الالتزام بالإجراءات الداخلية، التعاون ضمن الصلاحيات.
- ◀ **البروتوكولات والمعايير:** نظام مكافحة جرائم المعلوماتية السعودي.
- ◀ **الأجهزة أو الأدوات:** أنظمة معلومات، شبكات معلوماتية، سجلات، أدلة رقمية.
- ◀ وحدة البيانات أو المخرج: بلاغ أو سجل واقعة موثق.
- ◀ **مثال:** توثق الشركة محاولة وصول غير مفوض إلى حساب موظف وتصددها عبر المسار المعتمد.



نظام مكافحة جرائم المعلوماتية (الشكل)

SLIDE 21 · ELEMENT

نظام مكافحة جرائم المعلوماتية

نظام مكافحة جرائم المعلوماتية، نظام سعودي ساري، صدر بالمرسوم الملكي رقم (م/17) بتاريخ 13/1428هـ، الموافق 27/3/2007م. ويتضمن تعريفات وهدفاً وعقوبات لجرائم معلوماتية ومسؤولية الجهة التنظيمية الواردة في نبذة النظام.



الأجهزة والأدوات

- أنظمة معلومات
- شبكات معلوماتية
- سجلات
- أدلة رقمية

البروتوكولات والمعايير

- نظام مكافحة جرائم المعلوماتية السعودي

الوظائف الرئيسية

- تنظيم التعامل النظامي مع الأفعال غير المشروعة المرتبطة بالمعلوماتية
- عدم ارتكاب الأفعال المحظورة
- حفظ الأدلة والوقائع
- التصعيد للجهات المختصة
- الالتزام بالإجراءات الداخلية

توثق الشركة محاولة وصول غير مفوض إلى حساب موظف وتصددها عبر المسار المعتمد.

نظام مكافحة جرائم المعلوماتية نظام سعودي ساري، صدر بالمرسوم الملكي رقم (م/17) بتاريخ 8/3/1428هـ، الموافق 27/3/2007م.



- ◀ الجرائم الإلكترونية أفعال تتناولها أنظمة مكافحة الجرائم المعلوماتية أو جرائم تقنية المعلومات، وقد ترتبط بالأنظمة والشبكات والبيانات.
- ◀ وهي نطاق مختلف عن مخالفة سياسة داخلية أو خطأ تشغيلي يحتاج معالجة إدارية.
- ◀ **الوظيفة:** تحديد الوقائع التي قد تتطلب مساراً نظامياً مختصاً.
- ◀ **المسؤوليات:** منع الأفعال غير المشروعة، الإبلاغ عن الوقائع، حفظ السجل، عدم العبث بالأدلة، التنسيق مع الجهة المختصة.
- ◀ **البروتوكولات والمعايير:** نظام مكافحة جرائم المعلوماتية السعودي، قانون مصر رقم 175 لسنة 2018.
- ◀ **الأجهزة أو الأدوات:** أنظمة معلومات، شبكات معلوماتية، سجلات أنشطة، أدوات حفظ الأدلة.
- ◀ وحدة البيانات أو المخرج: واقعة موثقة أو بلاغ.
- ◀ **مثال:** استخدام حساب شخص آخر للوصول إلى خدمة رقمية دون تفويض يستلزم توثيق الواقعة وفحصها.



الجرائم الإلكترونية (Cybercrime) (الشكل)

SLIDE 22 · CYBERCRIME

الجرائم الإلكترونية



الأجهزة والأدوات

- أنظمة معلومات
- شبكات معلوماتية
- سجلات أنشطة
- أدوات حفظ الأدلة

البروتوكولات والمعايير

- نظام مكافحة جرائم المعلوماتية السعودي
- قانون مصر رقم 175 لسنة 2018

الوظائف الرئيسية

- تحديد الوقائع التي قد تتطلب مساراً نظامياً مختصاً
- منع الأفعال غير المشروعة
- الإبلاغ عن الوقائع
- حفظ السجل
- عدم العبث بالأدلة

استخدام حساب شخص آخر للوصول إلى خدمة رقمية دون تفويض يستلزم توثيق الواقعة وفحصها.

الجرائم الإلكترونية أفعال تتناولها أنظمة مكافحة الجرائم المعلوماتية أو جرائم تقنية المعلومات، وقد ترتبط بالأنظمة والشبكات والبيانات.

(Unauthorized Access) الدخول غير المصرح

- ◀ الدخول غير المصرح مفهوم يندرج ضمن موضوعات الجرائم المعلوماتية وجرائم تقنية المعلومات.
- ◀ يدرس بوصفه مؤشراً لواقعة تستلزم الاحتواء والتوثيق والتصعيد، لا بوصفه حكماً قانونياً نهائياً يصدره الموظف أو الطالب.
- ◀ **الوظيفة:** تنبيه المؤسسة إلى واقعة تتطلب استجابة منضبطة.
- ◀ **المسؤوليات:** وقف الاستخدام غير المصرح، حفظ السجل، الإبلاغ، عدم تغيير الأدلة، مراجعة الصلاحيات.
- ◀ **البروتوكولات والمعايير:** نظام مكافحة جرائم المعلوماتية، ISO/IEC 27002 للتحكم في الوصول.
- ◀ **الأجهزة أو الأدوات:** سجلات الوصول، نظام إدارة هويات، تذاكر حوادث، ضوابط التحكم في الوصول.
- ◀ وحدة البيانات أو المخرج: سجل حدث وصول أو بلاغ واقعة.
- ◀ **مثال:** استخدام بيانات اعتماد موظف آخر للوصول إلى سجلات خدمة يستدعي التوثيق والتصعيد.



الدخول غير المصرح (Unauthorized Access) (الشكل)

SLIDE 23 · UNAUTHORIZED ACCESS

الدخول غير المصرح



سجل حدث وصول أو بلاغ واقعة.

الأجهزة والأدوات

- سجلات الوصول
- نظام إدارة هويات
- تذاكر حوادث
- ضوابط التحكم في الوصول

البروتوكولات والمعايير

- نظام مكافحة جرائم المعلوماتية
- ISO/IEC 27002 للتحكم في الوصول

الوظائف الرئيسية

- تنبيه المؤسسة إلى واقعة تتطلب استجابة منضبطة
- وقف الاستخدام غير المصرح
- حفظ السجل
- الإبلاغ
- عدم تغيير الأدلة

استخدام بيانات اعتماد موظف آخر للوصول إلى سجلات خدمة يستدعي التوثيق والتصعيد.

الدخول غير المصرح مفهوم يندرج ضمن موضوعات الجرائم المعلوماتية وجرائم تقنية المعلومات.



(Data Disclosure) إفشاء البيانات

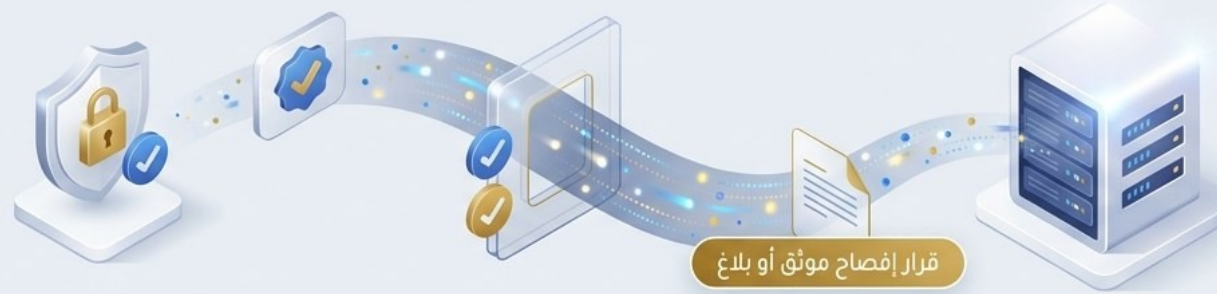
- ◀ إفشاء البيانات هو إتاحة البيانات أو كشفها بصورة تستلزم فحص الغرض والصلاحيّة والجهة المتلقية والضمانات التنظيمية.
- ◀ ويجب تحليل الإفصاح قبل تنفيذه، خصوصاً عند تعلقه ببيانات شخصية أو أكاديمية.
- ◀ **الوظيفة:** ضبط قرارات مشاركة البيانات مع الجهات والأفراد.
- ◀ **المسؤوليات:** التحقق من الصلاحيّة، تقليل البيانات، توثيق القرار، استخدام قناة معتمدة، التصعيد عند الاشتباه.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، لوائحه، ISO/IEC 27002.
- ◀ **الأجهزة أو الأدوات:** سجل إفصاح، نموذج طلب بيانات، قناة مشاركة معتمدة، سجل بلاغ.
- ◀ وحدة البيانات أو المخرج: قرار إفصاح موثق أو بلاغ.
- ◀ **مثال:** لا ترسل الشركة كشف درجات في مجموعة محادثة غير معتمدة لتسريع حل مشكلة تشغيلية.



إفشاء البيانات (Data Disclosure) (الشكل)

SLIDE 24 · DATA DISCLOSURE

إفشاء البيانات



الأجهزة والأدوات

- سجل إفصاح
- نموذج طلب بيانات
- قناة مشاركة معتمدة
- سجل بلاغ

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- لوائحه
- ISO/IEC 27002

الوظائف الرئيسية

- ضبط قرارات مشاركة البيانات مع الجهات والأفراد
- التحقق من الصلاحية
- تقليل البيانات
- توثيق القرار
- استخدام قناة معتمدة

لا ترسل الشركة كشف درجات في مجموعة محادثة غير معتمدة لتسريع حل مشكلة تشغيلية

إفشاء البيانات هو إتاحة البيانات أو كشفها بصورة تستلزم فحص الغرض والصلاحية والجهة المتلقية والضمانات التنظيمية.



نشاط تطبيقي، فرز مسؤوليات واقعة خصوصية



- ◀ حل واقعة إرسال ملف كشف درجات إلى بريد شخصي ثم مشاركته عبر قناة غير معتمدة.
- ◀ اكتب في ثلاثة أسطر مسؤولية الموظف، ومسؤولية المنظمة، والإجراء الوقائي المقابل.
- ◀ لا تصف الواقعة بجريمة أو مخالفة نظامية نهائية.
- ◀ ركز على الوقائع الموثقة، وحفظ الأدلة، والقناة المعتمدة، ومالك المعالجة، ومسار التصعيد الداخلي.



- ◀ يلتزم الموظف بالإبلاغ وعدم مشاركة الملف خارج القناة المعتمدة وعدم العبث بالسجلات.
- ◀ تراجع المنظمة صلاحيات تصدير كشف الدرجات، وتوفر قناة عمل آمنة، وتكلف مالك المعالجة بمتابعة البلاغ.
- ◀ ويتمثل الإجراء الوقائي في ضبط التصدير وتأكيد استخدام القناة المعتمدة وتنفيذ توعية موجهة.
- ◀ يبقى التكييف القانوني النهائي من اختصاص الجهة المختصة.

بلاغ داخلي عن حادثة خصوصية

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين

جازان، المملكة العربية السعودية

الرقم الضريبي: 300000000000003 - السجل التجاري: 1010000000

هاتف: 0500000000

النموذج: بلاغ داخلي عن واقعة خصوصية

تاريخ البلاغ:

2026-04-16

تاريخ اكتشاف الواقعة:

2026-04-16

وصف الواقعة:

تمت مشاركة ملف كشف درجات يضم بيانات مستفيدين عبر مجموعة محادثة غير معتمدة بعد إرساله إلى بريد شخصي بغرض استكمال العمل خارج القناة المؤسسية.

البيانات المتأثرة:

أسماء مستفيدين، أرقام تعليمية داخلية، مقررات، درجات، وعناوين بريد إلكتروني.

مصدر السجل المرتبط:

سجل معالجة البيانات الشخصية: نشاط إصدار كشف درجات للمستفيد.

التصنيف الأولي:

اشتباه إفشاء غير مصرح به لبيانات شخصية وأكاديمية، ويتطلب تقييماً داخلياً عاجلاً.

إجراءات الاحتواء الفورية:

طلب حذف الملف من البريد الشخصي ومجموعة المحادثة، تعطيل أي رابط مشاركة، وحفظ الأدلة المتاحة دون تعديل.

مسار التصعيد الداخلي:

إخطار مالك المعالجة وإدارة المنصات التعليمية ووحدة الخصوصية والإدارة القانونية وفق الإجراءات المعتمدة.

التقييم المطلوب:

تحديد نطاق الوصول الفعلي، وعدد المستفيدين المتأثرين، واحتمال الضرر، والحاجة إلى إجراءات إبلاغ إضافية.

إجراء تصحيحي مبدئي:

مراجعة صلاحيات تصدير كشف الدرجات، وتأكد استخدام القناة المعتمدة، وتنفيذ توعية موجهة للموظفين.

المحتوى للتدريب على التوثيق والتصعيد التنظيمي الأولي، ولا يمثل توصيفاً قضائياً أو استشارة قانونية.

مقدم الطلب

المسؤول

الاعتماد

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يسجل هذا النموذج بلاغاً بتاريخ 2026-04-16 عن مشاركة ملف كشف درجات عبر قناة غير معتمدة بعد إرساله إلى بريد شخصي.
- تشمل البيانات المتأثرة أسماء المستفيدين والأرقام التعليمية الداخلية والمقررات والدرجات وعناوين البريد الإلكتروني.
- يوجه النموذج المتعلم إلى تمييز الوقائع الموثقة عن التكييف القانوني، ثم تحديد الاحتواء والتصعيد الداخلي والتقييم المطلوب قبل اتخاذ قرار إضافي.

مثال محلول، تحليل مشاركة كشف درجات

- المعطيات: في 2026-04-16 شارك موظف ملف كشف درجات عبر مجموعة محادثة غير معتمدة بعد إرساله إلى بريد شخصي لاستكمال العمل.
- ويشمل الملف أسماء مستفيدين وأرقامهم التعليمية الداخلية ومقرراتهم ودرجاتهم وعناوين بريدهم الإلكتروني.

الخطوات:

1. تحدد البيانات المتأثرة بوصفها بيانات شخصية وأكاديمية.
 2. تربط الواقعة بنشاط إصدار كشف درجات في سجل المعالجة.
 3. تطلب حذف الملف وتعطيل رابط المشاركة وتحفظ الأدلة دون تعديل.
 4. تخطر مالك المعالجة وإدارة المنصات التعليمية ووحدة الخصوصية والإدارة القانونية.
 5. تقيم نطاق الوصول الفعلي وعدد المستفيدين المتأثرين واحتمال الضرر والحاجة إلى إجراءات إبلاغ إضافية.
- الناتج: بلاغ داخلي موثق واستجابة تنظيمية أولية تشمل الاحتواء وحفظ الأدلة والتصعيد والتقييم القابل للمتابعة.

CASE - GRADE FILE SHARE

مثال محلول: تحليل مشاركة كشف درجات

المعطيات: 2026-04-16

موظف أرسل كشف درجات إلى بريد شخصي ثم شاركه في مجموعة محادثة غير معتمدة. المحتوى: أسماء مستفيدين، أرقام تعليمية داخلية، مقررات، درجات، عناوين بريد إلكتروني.

5	4	3	2	1
تقييم النطاق الوصول الفعلي عدد المتأثرين الضرر والإبلاغ	إخطار الجهات مالك المعالجة المنصات والخصوصية الإدارة القانونية	احتواء فوري حذف وتعطيل الرابط حفظ الأدلة دون تعديل	رابط الواقعة نشاط إصدار كشف في سجل المعالجة	تحديد البيانات شخصية وأكاديمية وصف المتأثر

الناتج: بلاغ داخلي موثق واستجابة تنظيمية أولية الاحتواء، حفظ الأدلة، التصعيد، والتقييم القابل للمتابعة

التحليل يربط الواقعة بسجل المعالجة ثم يحتوى ويُصقّد ويُقِيم دون اختراع وقائع.



إساءة استخدام البيانات (Data Misuse)



- ◀ إساءة استخدام البيانات هي استخدام البيانات أو الصلاحيات على نحو يخرج عن غرض العمل أو الإطار النظامي والسياسي المقرر.
- ◀ وتعد مؤشراً لمخاطر قانونية ومهنية وتنظيمية تحتاج إلى تحليل وتوثيق.
- ◀ **الوظيفة:** كشف الاستخدام غير المرتبط بالغرض أو الصلاحية.
- ◀ **المسؤوليات:** الالتزام بالغرض، قصر الاستخدام على الصلاحية، الإبلاغ عن المخالفة، حماية السجلات، التعاون في المراجعة.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، نظام مكافحة جرائم المعلوماتية، سياسات المؤسسة، ISO/IEC 27002.
- ◀ **الأجهزة أو الأدوات:** سجلات استخدام، ضوابط وصول، سجل قرار، نموذج بلاغ.
- ◀ وحدة البيانات أو المخرج: تقرير مخالفة أو إجراء تصحيحي.
- ◀ **مثال:** لا تستخدم الشركة بيانات اتصال جُمعت لخدمة الدعم في غرض تسويقي غير مرتبط بالخدمة.



إساءة استخدام البيانات (Data Misuse) (الشكل)

SLIDE 27 • DATA MISUSE

إساءة استخدام البيانات

إساءة استخدام البيانات هي استخدام البيانات أو الصلاحيات على نحو يخرج عن غرض العمل أو الإطار النظامي والسياسي المقرر. وتعد مؤشراً لمخاطر قانونية ومهنية وتنظيمية تحتاج إلى تحليل وتوثيق.



الأجهزة والأدوات

- سجلات استخدام
- ضوابط وصول
- سجل قرار
- نموذج بلاغ

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- نظام مكافحة جرائم المعلوماتية
- سياسات المؤسسة
- ISO/IEC 27002

الوظائف الرئيسية

- كشف الاستخدام غير المرتبط بالغرض أو الصلاحية
- الالتزام بالغرض
- قصر الاستخدام على الصلاحية
- الإبلاغ عن المخالفة
- حماية السجلات

لا تستخدم الشركة بيانات اتصال جُمعت لخدمة الدعم في غرض تسويقي غير مرتبط بالخدمة.

إساءة استخدام البيانات هي استخدام البيانات أو الصلاحيات على نحو يخرج عن غرض العمل أو الإطار النظامي والسياسي المقرر.



(Digital Evidence) الدليل الرقمي

- ◀ الدليل الرقمي مخرجات أو سجلات رقمية مرتبطة بواقعة معلوماتية، وتحتاج إلى حفظ وتوثيق ضمن مسار الاستجابة والتقصيد.
- ◀ ويخدم فهم الواقعة وتمكين المراجعة أو الإحالة للجهات المختصة ضمن الصلاحيات.
- ◀ **الوظيفة:** دعم توثيق الواقعة ومراجعتها.
- ◀ **المسؤوليات:** حفظ الوقائع، عدم العبث بالسجلات، تقييد الوصول، توثيق المستلم، تسليم الأدلة عبر المسار المعتمد.
- ◀ **البروتوكولات والمعايير:** نظام مكافحة جرائم المعلوماتية، ضوابط ISO/IEC 27002 لإدارة الحوادث والسجلات.
- ◀ **الأجهزة أو الأدوات:** سجلات النظام، تذاكر الحوادث، مستودع أدلة محكوم الوصول.
- ◀ وحدة البيانات أو المخرج: ملف سجل أو تقرير واقعة.
- ◀ **مثال:** تحفظ الشركة سجل الدخول ووقت الحدث ومعرف الحساب عند الاشتباه في وصول غير مصرح.



الدليل الرقمي (Digital Evidence) (الشكل)

SLIDE 28 · DIGITAL EVIDENCE

الدليل الرقمي



الأجهزة والأدوات

- سجلات النظام
- تذاكر الحوادث
- مستودع أدلة محكوم الوصول

البروتوكولات والمعايير

- نظام مكافحة جرائم المعلوماتية
- ضوابط ISO/IEC 27002 لإدارة الحوادث والسجلات

الوظائف الرئيسية

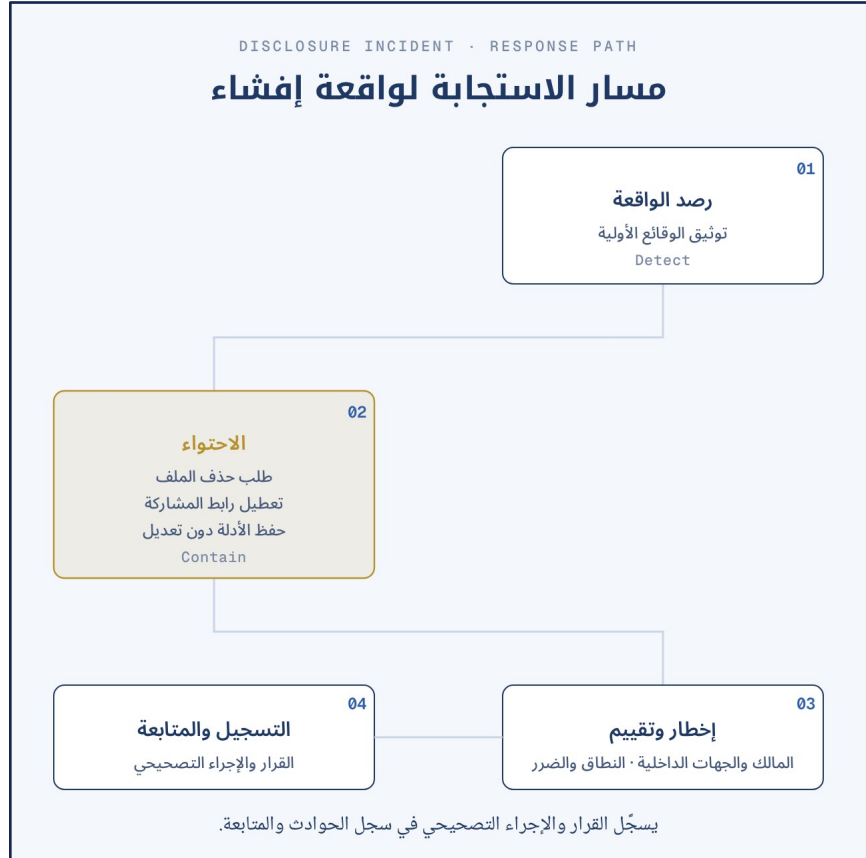
- دعم توثيق الواقعة ومراجعتها
- حفظ الوقائع
- عدم العبث بالسجلات
- تقييد الوصول
- توثيق المستلم

تحفظ الشركة سجل الدخول ووقت الحدث ومعرف الحساب عند الاشتباه في وصول غير مصرح.

الدليل الرقمي مخرجات أو سجلات رقمية مرتبطة بواقعة معلوماتية، وتحتاج إلى حفظ وتوثيق ضمن مسار الاستجابة والتصعيد.



شكل توضيحي، مسار الاستجابة لواقعة إفشاء



- ◀ يبدأ مسار الاستجابة برصد الواقعة وتوثيق الوقائع الأولية.
- ◀ ثم تطبق الشركة الاحتواء، مثل طلب حذف الملف وتعطيل رابط المشاركة، وتحفظ الأدلة المتاحة دون تعديل.
- ◀ بعد ذلك تخطر مالك المعالجة والجهات الداخلية المختصة، وتقيم نطاق الوصول والضرر المحتمل والحاجة إلى إجراءات إضافية.
- ◀ يسجل القرار والإجراء التصحيحي في سجل الحوادث والمتابعة.



اللائحة العامة لحماية البيانات (GDPR)



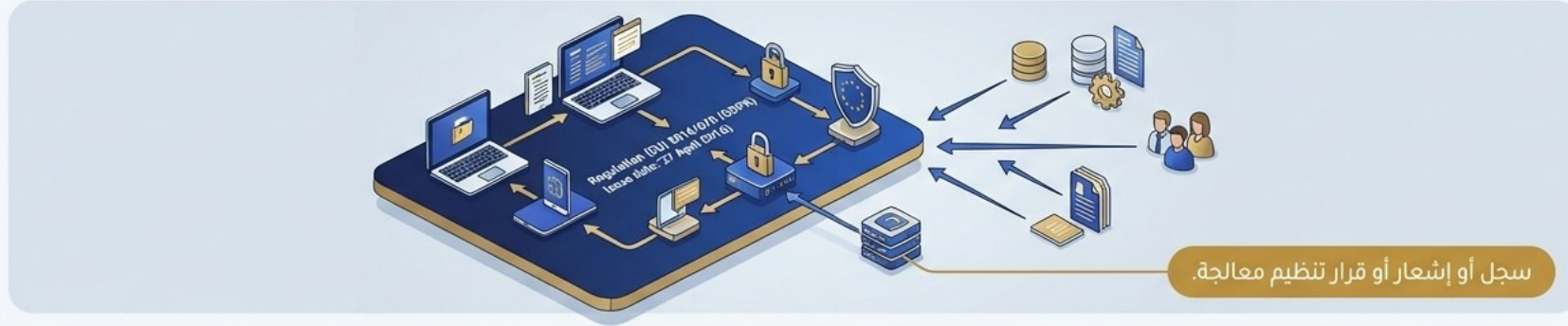
- ◀ اللائحة العامة لحماية البيانات هي Regulation (EU) 2016/679 الصادرة في 27 أبريل 2016 لحماية الأشخاص الطبيعيين عند معالجة بياناتهم الشخصية وحرية انتقالها.
- ◀ وتعرض في هذا الفصل بوصفها إطاراً مقارناً للمفاهيم التنظيمية.
- ◀ **الوظيفة:** تقديم إطار أوروبي لحماية البيانات ومفهوم جهة التحكم.
- ◀ **المسؤوليات:** تحديد الأغراض والوسائل، مراعاة حماية البيانات، توثيق المعالجة، تنظيم الأدوار، مراجعة الانطباق بحسب السياق.
- ◀ **البروتوكولات والمعايير:** GDPR, CELEX: 32016R0679.
- ◀ **الأجهزة أو الأدوات:** سجل معالجة، سياسة خصوصية، سجل قرارات تنظيمية.
- ◀ وحدة البيانات أو المخرج: سجل أو إشعار أو قرار تنظيم معالجة.
- ◀ **مثال:** تقارن الشركة مفهوم جهة التحكم بمسؤولية الجهة التي تحدد غرض خدمة رقمية.



اللائحة العامة لحماية البيانات (GDPR) (الشكل)

SLIDE 29 · GDPR

اللائحة العامة لحماية البيانات



الأجهزة والأدوات

- سجل معالجة
- سياسة خصوصية
- سجل قرارات تنظيمية

البروتوكولات والمعايير

- GDPR
- CELEX: 32016R0679

الوظائف الرئيسية

- تقديم إطار أوروبي لحماية البيانات ومفهوم جهة التحكم
- تحديد الأغراض والوسائل
- مراعاة حماية البيانات
- توثيق المعالجة
- تنظيم الأدوار

تقارن الشركة مفهوم جهة التحكم بمسؤولية الجهة التي تحدد غرض خدمة رقمية.

اللائحة العامة لحماية البيانات هي Regulation (EU) 2016/679 الصادرة في 27 أبريل 2016 لحماية الأشخاص الطبيعيين عند معالجة بياناتهم الشخصية وحرية انتقالها.



نطاق الاختصاص القانوني (Legal Jurisdiction)



- ◀ نطاق الاختصاص القانوني هو حدود انطباق نظام أو لائحة بحسب الجهة والواقعة والمكان وطبيعة المعالجة أو الفعل.
- ◀ وظيفته توجيه المؤسسة إلى النظام المرجعي ومسار التصعيد المناسب، لا إصدار حكم قانوني نهائي داخل النشاط التعليمي.
- ◀ **الوظيفة:** تحديد الحاجة إلى إحالة المسألة للجهة المختصة.
- ◀ **المسؤوليات:** تحديد موقع الجهة والبيانات، فحص نوع الخدمة، تحديد الأطراف، إحالة المسألة للمختص، توثيق الافتراضات.
- ◀ **البروتوكولات والمعايير:** النظام السعودي، GDPR، قانون مصر رقم 175 لسنة 2018.
- ◀ **الأجهزة أو الأدوات:** سجل معالجة، خريطة تدفق بيانات، سجل قرارات.
- ◀ وحدة البيانات أو المخرج: مذكرة تصعيد أو تحليل أولي للنطاق.
- ◀ **مثال:** تراجع الشركة قواعد نقل البيانات عند استخدام مزود خدمة خارج المملكة.



نطاق الاختصاص القانوني (Legal Jurisdiction) (الشكل)

SLIDE 30 · LEGAL JURISDICTION

نطاق الاختصاص القانوني



الأجهزة والأدوات

- سجل معالجة
- خريطة تدفق بيانات
- سجل قرارات

البروتوكولات والمعايير

- النظام السعودي
- GDPR
- قانون مصر رقم 175 لسنة 2018

الوظائف الرئيسية

- تحديد الحاجة إلى إحالة المسألة للجهة المختصة
- تحديد موقع الجهة والبيانات
- فحص نوع الخدمة
- تحديد الأطراف
- إحالة المسألة للمختص

تراجع الشركة قواعد نقل البيانات عند استخدام مزود خدمة خارج المملكة

نطاق الاختصاص القانوني هو حدود انطباق نظام أو لائحة بحسب الجهة والواقعة والمكان وطبيعة المعالجة أو الفعل



نشاط تطبيقي، مقارنة مساري واقعتين



- ◀ قارن بين استخدام أرقام جوال جُمعت للحجز في حملة تسويقية دون مسوغ مستقل، وبين الاشتباه في دخول غير مصرح إلى نظام.
- ◀ حدد لكل واقعة المسار التنظيمي الأولي وإجراءً أولياً واحداً.
- ◀ لا تفترض أن مخالفة السياسة وحدها تثبت جريمة معلوماتية، ولا تفترض أن المقارنة مع GDPR تحدد الانطباق الفعلي على الشركة.



- ◀ استخدام أرقام الجوال في التسويق يرتبط بحوكمة معالجة البيانات الشخصية.
- ◀ توقف الشركة الاستخدام وتراجع سجل المعالجة والمسوغ المستقل.
- ◀ أما الاشتباه في دخول غير مصرح فيتطلب احتواء الواقعة وحفظ الأدلة الرقمية وتقييد الوصول والتصعيد وفق الإجراءات.
- ◀ ويعرض قانون مصر رقم 175 لسنة 2018 بوصفه نموذجاً تشريعياً عربياً مقارناً، لا أساساً لتحديد حكم في المملكة.

جدول مقارنة مفاهيمية للأطر التنظيمية

المستند: مقارنة مفاهيم الخصوصية وحماية المعلومات

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000003 - السجل التجاري: 1010000000
هاتف: 0500000000

مقارنة مفاهيم الخصوصية وحماية المعلومات

مقارنة تعليمية عامة بين نظام حماية البيانات الشخصية السعودي وGDPR ومكافحة الجرائم المعلوماتية

البعد المقارن	حماية البيانات الشخصية في السياق السعودي	اللائحة العامة لحماية البيانات GDPR	مكافحة الجرائم المعلوماتية	الأثر العملي على المنشأة
الغاية الأساسية	تنظيم معالجة البيانات الشخصية وحماية خصوصية صاحب البيانات.	حماية البيانات الشخصية وتنظيم معالجتها ضمن نطاقها التنظيمي.	مواجهة الأفعال غير المشروعة المرتبطة بالأنظمة والشبكات والبيانات.	تحديد ما إذا كانت الواقعة تتعلق بحوكمة المعالجة أو بسلوك تقني غير مشروع أو بكليهما.
مثال للواقعة	استخدام أرقام جوال جُمعت للحجز في حملة تسويقية دون مسوغ مستقل مناسب.	معالجة بيانات لغرض جديد لا يتوافق مع الغرض المعلن أو الأساس المعتمد.	دخول غير مصرح به إلى نظام أو الاستيلاء على بيانات أو تعطيل خدمة.	توقف المنشأة الاستخدام محل الإشكال، وثائق الواقعة، وتحليلها للمسار الداخلي المختص.
المبدأ أو محور التقييم	تحديد الغرض، تقليل البيانات، الشفافية، وحماية حقوق صاحب البيانات.	المشروعية والشفافية وتحديد الغرض وتقليل البيانات وحقوق صاحب البيانات.	مشروعية الوصول، وسلامة الأنظمة، ومنع الاعتداء على البيانات أو الخدمات.	لا يكفي وصف الواقعة بأنها مخالفة سياسة، بل يلزم تقييم الوقائع والأدلة والمسار النظامي المناسب.
الاستجابة المؤسسية الأولية	مراجعة سجل المعالجة، احتواء الأثر، تقييم المخاطر، وتحديد متطلبات الإخطار أو التصعيد.	تقييم نطاق التطبيق والالتزامات المرتبطة بالواقعة عند انطباق اللائحة.	حفظ الأدلة الرقمية، تقييد الوصول، والتصعيد للجهات المختصة وفق الإجراءات.	يؤثق فريق العمل القرار الأولي ويرفع الحالات ذات الأثر القانوني المحتمل إلى الإدارة القانونية ووحدة الخصوصية.

المقارنة على مستوى المفاهيم التعليمية العامة وليست تفسيراً قانونياً أو حكماً على واقعة محددة.

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

- يعرض الجدول الفرق بين تنظيم معالجة البيانات الشخصية وبين مكافحة الأفعال غير المشروعة المرتبطة بالأنظمة والشبكات والبيانات.
- في حالة استخدام رقم جوال جُمع للحجز في حملة تسويقية، تراجع الشركة الغرض والسجل والمسوغ المستقل.
- أما عند الاشتباه بدخول غير مصرح، فتحفظ الأدلة وتفيد الوصول وتصعد الواقعة وفق الإجراءات المعتمدة.



جدول التمييز بين حماية البيانات ومكافحة الجرائم المعلوماتية

البعد	حماية البيانات الشخصية	مكافحة الجرائم المعلوماتية	الإجراء الأولي
محور الواقعة	غرض المعالجة والبيانات والشفافية	سلوك غير مشروع محتمل يتعلق بالنظام أو البيانات	توثيق الوقائع وتحديد المسار
مثال	استخدام بيانات الحجز في تسويق غير معلن	اشتباہ دخول غير مصرح إلى حساب	إيقاف الاستخدام أو تقييد الوصول
الدليل التنظيمي	سجل المعالجة وإشعار الخصوصية	سجل الوصول والأدلة الرقمية	التصعيد إلى المالك المختص

هذا الجدول أداة فرز أولي.
ولا يصدر الموظف من خلاله حكماً قانونياً نهائياً، بل يوثق الواقعة ويحيلها إلى القناة المعتمدة عند وجود أثر نظامي محتمل.

(Contractual Compliance) الالتزام التعاقدي

- ◀ الالتزام التعاقدي هو التزامات تنشأ من العقود أو الاتفاقات وقد تكمل الالتزامات النظامية، لكنها لا تلغيها.
- ◀ وظيفته تنظيم مسؤوليات الأطراف وأدلة الأداء ومتطلبات التعامل مع المعلومات ضمن العلاقة المؤسسية.
- ◀ **الوظيفة:** ضبط التزامات الأطراف والموردين.
- ◀ **المسؤوليات:** مراجعة الالتزام التعاقدي، تحديد مالك العقد، توثيق الضوابط، إدارة الموردين، تصعيد التعارضات القانونية.
- ◀ **البروتوكولات والمعايير:** ISO/IEC 27001, ISO/IEC 27002, NIST CSF 2.0.
- ◀ **الأجهزة أو الأدوات:** عقد، سجل التزامات، مصفوفة مسؤوليات، سجل أدلة.
- ◀ وحدة البيانات أو المخرج: بند تعاقدي أو قرار معالجة فجوة.
- ◀ **مثال:** تشترط الشركة استخدام قناة نقل معتمدة عند مشاركة بيانات خدمة مع مزود خارجي.



الالتزام التعاقدي (Contractual Compliance) (الشكل)

SLIDE 32 · CONTRACTUAL COMPLIANCE

الالتزام التعاقدي

الالتزام التعاقدي هو التزامات تنشأ من العقود أو الاتفاقات وقد تكمل الالتزامات النظامية، لكنها لا تلغيها. وظيفته تنظيم مسؤوليات الأطراف وأدلة الأداء ومتطلبات التعامل مع المعلومات ضمن العلاقة المؤسسية.



بند تعاقدي أو قرار معالجة فحوة

الأجهزة والأدوات

- عقد
- سجل التزامات
- مصفوفة مسؤوليات
- سجل أدلة

البروتوكولات والمعايير

- ISO/IEC 27001
- ISO/IEC 27002
- NIST CSF 2.0

الوظائف الرئيسية

- ضبط التزامات الأطراف والموردين
- مراجعة الالتزام التعاقدي
- تحديد مالك العقد
- توثيق الضوابط
- إدارة الموردين

تشتتر الشركة استخدام قناة نقل معتمدة عند مشاركة بيانات خدمة مع مزود خارجي.

الالتزام التعاقدي هو التزامات تنشأ من العقود أو الاتفاقات وقد تكمل الالتزامات النظامية، لكنها لا تلغيها.



شكل توضيحي، هرم الأطر التنظيمية في الشركة



- ◀ ينظم الهرم العلاقة بين أربعة مستويات.
- ◀ في القمة تقع الأنظمة واللوائح الوطنية، مثل نظام حماية البيانات الشخصية ونظام مكافحة جرائم المعلوماتية.
- ◀ يليها المستوى القطاعي والضوابط الوطنية ذات الصلة.
- ◀ ثم تأتي السياسات المؤسسية التي تحدد السلوك والأدوار.
- ◀ وتشكل الإجراءات وضوابط التشغيل القاعدة التي تنفذ السياسة وتنتج السجلات والأدلة القابلة للمراجعة.



(Regulatory Reporting) الإبلاغ التنظيمي

- الإبلاغ التنظيمي مسار إبلاغ ومتابعة يتعلق بالالتزامات النظامية أو الرقابية أو المؤسسية عند وقوع واقعة ذات صلة.
- يبدأ برصد الواقعة وتوثيق الوقائع الأولية المتاحة، ثم التصعيد للجهة المالكة ومتابعة الإجراء التصحيحي.
- الوظيفة:** تمكين الجهة المختصة من متابعة الواقعة والالتزام.
- المسؤوليات:** تحديد الواقعة، جمع الوقائع الأولية، التصعيد في الوقت المناسب، توثيق القرار، متابعة الإجراء التصحيحي.
- البروتوكولات والمعايير:** نظام حماية البيانات الشخصية ولوائحه، ISO/IEC 27002 لإدارة الحوادث.
- الأجهزة أو الأدوات:** نموذج بلاغ داخلي، سجل حادث، قناة تصعيد، سجل متابعة.
- وحدة البيانات أو المخرج: بلاغ أو تقرير واقعة أو تحديث حالة.
- مثال:** يرفع الموظف بلاغاً داخلياً بعد إرسال ملف بيانات شخصية إلى مستلم غير مقصود.



الإبلاغ التنظيمي (Regulatory Reporting) (الشكل)

SLIDE 33 · REGULATORY REPORTING

الإبلاغ التنظيمي



الأجهزة والأدوات

- نموذج بلاغ داخلي
- سجل حادث
- قناة تصعيد
- سجل متابعة

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية ولوائحه
- ISO/IEC 27002 لإدارة الحوادث

الوظائف الرئيسية

- تمكين الجهة المختصة من متابعة الواقعة والالتزام
- تحديد الواقعة
- جمع الوقائع الأولية
- التصعيد في الوقت المناسب
- توثيق القرار

يرفع الموظف بلاغاً داخلياً بعد إرسال ملف بيانات شخصية إلى مستلم غير مقصود

الإبلاغ التنظيمي مسار إبلاغ ومتابعة يتعلق بالالتزامات النظامية أو الرقابية أو المؤسسية عند وقوع واقعة ذات صلة



حفظ السجلات (Record Retention)

- ◀ حفظ السجلات هو تنظيم السجلات التي تثبت الأغراض والأدوار والمعالجة والالتزام أو الوقائع.
- ◀ والسجل ليس وثيقة شكلية، بل أثر قابل للمراجعة يوضح من قرر وماذا عالج ولماذا ومتى.
- ◀ **الوظيفة:** توفير دليل قابل للمراجعة للقرارات والأنشطة.
- ◀ **المسؤوليات:** تحديد السجل، تحديد المالك، ضبط الوصول، تحديث السجل، مراجعة اكتماله.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، NIST CSF 2.0، ISO/IEC 27002، ISO/IEC 27001.
- ◀ **الأجهزة أو الأدوات:** سجل معالجة، سجل وصول، سجل بلاغات، سجل قرارات.
- ◀ وحدة البيانات أو المخرج: سجل موثق قابل للمراجعة.
- ◀ **مثال:** يحفظ سجل الحجز نوع البيانات والغرض والمالك وفترة الاحتفاظ.



حفظ السجلات (Record Retention) (الشكل)

SLIDE 34 · RECORD RETENTION

حفظ السجلات



سجل موثق قابل للمراجعة.

الأجهزة والأدوات

- سجل معالجة
- سجل وصول
- سجل بلاغات
- سجل قرارات

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- ISO/IEC 27001
- ISO/IEC 27002
- NIST CSF 2.0

الوظائف الرئيسية

- توفير دليل قابل للمراجعة للقرارات والأنشطة
- تحديد السجل
- تحديد المالك
- ضبط الوصول
- تحديث السجل

يحفظ سجل الحجز نوع البيانات والغرض والمالك وفترة الاحتفاظ.

حفظ السجلات هو تنظيم السجلات التي تثبت الأغراض والأدوار والمعالجة والالتزام أو الوقائع.



- الموافقة مفهوم تنظيمي قد يكون من مسوغات أو عناصر تنظيم معالجة البيانات بحسب النظام الواجب التطبيق.
- وتوثق اختيار أو إقرار صاحب البيانات في الحالات التي يتطلب فيها الإطار المنطبق ذلك.
- الوظيفة:** توثيق اختيار صاحب البيانات عند الحاجة.
- المسؤوليات:** تحديد الحاجة للموافقة، توثيقها عند اللزوم، ربطها بالغرض، عدم توسيع استخدامها، إحالة الحالات المعقدة للمختص.
- البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، GDPR.
- الأجهزة أو الأدوات:** نموذج موافقة، سجل معالجة، إشعار خصوصية.
- وحدة البيانات أو المخرج: سجل موافقة أو قرار مسوغ المعالجة.
- مثال:** توثق الشركة اختيار المستفيد تلقي رسائل تسويقية منفصلة عن رسائل الخدمة.



الموافقة (Consent) (الشكل)

SLIDE 35 · CONSENT

الموافقة



الأجهزة والأدوات

- نموذج موافقة
- سجل معالجة
- إشعار خصوصية

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- GDPR

الوظائف الرئيسية

- توثيق اختيار صاحب البيانات عند الحاجة
- تحديد الحاجة للموافقة
- توثيقها عند اللزوم
- ربطها بالغرض
- عدم توسيع استخدامها

توثق الشركة اختيار المستفيد تلقي رسائل تسويقية منفصلة عن رسائل الخدمة.

الموافقة مفهوم تنظيمي قد يكون من مسوغات أو عناصر تنظيم معالجة البيانات بحسب النظام الواجب التطبيق.



نشاط تطبيقي، قرار استخدام بيانات الحجز



- ◀ تريد إدارة التسويق استخدام رقم الجوال والبريد الإلكتروني اللذين جمعتهما خدمة الحجز لإرسال عرض تجاري جديد.
- ◀ اكتب قراراً تنظيمياً أولاً من ثلاث خطوات.
- ◀ ابدأ بتحديد الغرض الأصلي، ثم قارن الاستخدام المقترح بإشعار الخصوصية، ثم حدد الإجراء قبل أي استخدام جديد للبيانات.
- ◀ اجعل القرار قابلاً للتوثيق في سجل المعالجة.



- ◀ الغرض الأصلي هو إنشاء الحساب وتأکید الحجز وتقديم الخدمة والتواصل بشأن الطلب أو الدعم الفني.
- ◀ لا يدخل العرض التجاري الجديد ضمن هذا الغرض المعلن.
- ◀ توقف الشركة استخدام القائمة المقترح، ثم تراجع الجهة المختصة وجود مسوغ مستقل وموافقة منفصلة عند الاقتضاء قبل أي معالجة تسويقية.
- ◀ يوثق القرار ومبرره في سجل المعالجة وسجل القرارات.



إشعار الخصوصية والموافقة

شركة الحلول التقنية والخدمات الرقمية

إدارة المنصات التعليمية وتقديم الخدمات الرقمية للمستخدمين
جازان، المملكة العربية السعودية
الرقم الضريبي: 3000000000000000 - السجل التجاري: 1010000000
هاتف: 0500000000

النموذج: إشعار خصوصية وموافقة جمع بيانات

إشعار خصوصية وموافقة جمع بيانات

الخدمة:

خدمة حجز تعليمية رقمية ودعم فني للمستخدمين.

الغرض من الجمع:

إنشاء الحساب، تأكيد الحجز، تقديم الخدمة المطلوبة، والتواصل بشأن الطلب أو الدعم الفني.

البيانات التي تجمع:

الاسم، رقم الجوال، البريد الإلكتروني، نوع الخدمة، وتفاصيل طلب الدعم عند الحاجة.

البيانات غير المطلوبة لهذا الغرض:

لا تطلب الخدمة بيانات إضافية لا ترتبط بإنشاء الحساب أو الحجز أو الدعم الفني.

استخدام البيانات للتسويق:

لا تستخدم أرقام الجوال أو البريد الإلكتروني في العروض التسويقية ما لم يوجد مسوغ مستقل وموافقة منفصلة عند الاقتضاء.

المشاركة:

تقتصر المشاركة على فرق التشغيل والدعم الفني المخولة وبالقدر اللازم لتقديم الخدمة.

مدة الاحتفاظ:

تحفظ الشركة بالبيانات للمدة اللازمة للفرص المعلن أو وفق متطلبات الاحتفاظ المعمدة.

حقوق صاحب البيانات:

يمكن للمستخدم طلب الاستفسار عن معالجة بياناته أو تحديثها أو ممارسة الحقوق المتاحة عبر القنوات المعمدة.

قناة التواصل:

قناة الخصوصية وخدمة المستخدمين المعمدة لدى الشركة.

نص الموافقة:

أقر بأنني اطلعت على أغراض جمع بياناتي اللازمة لاستخدام الخدمة، وأفهم أن أي استخدام مستقل لأغراض تسويقية لا يدخل ضمن غرض الحجز والدعم الفني المعلن.

نموذج تعليمي يوضح مبدأ الشفافية وتحديد الغرض. تطبق المنظمة النص النهائي وفق مراجعتها النظامية وإجراءاتها المعمدة.

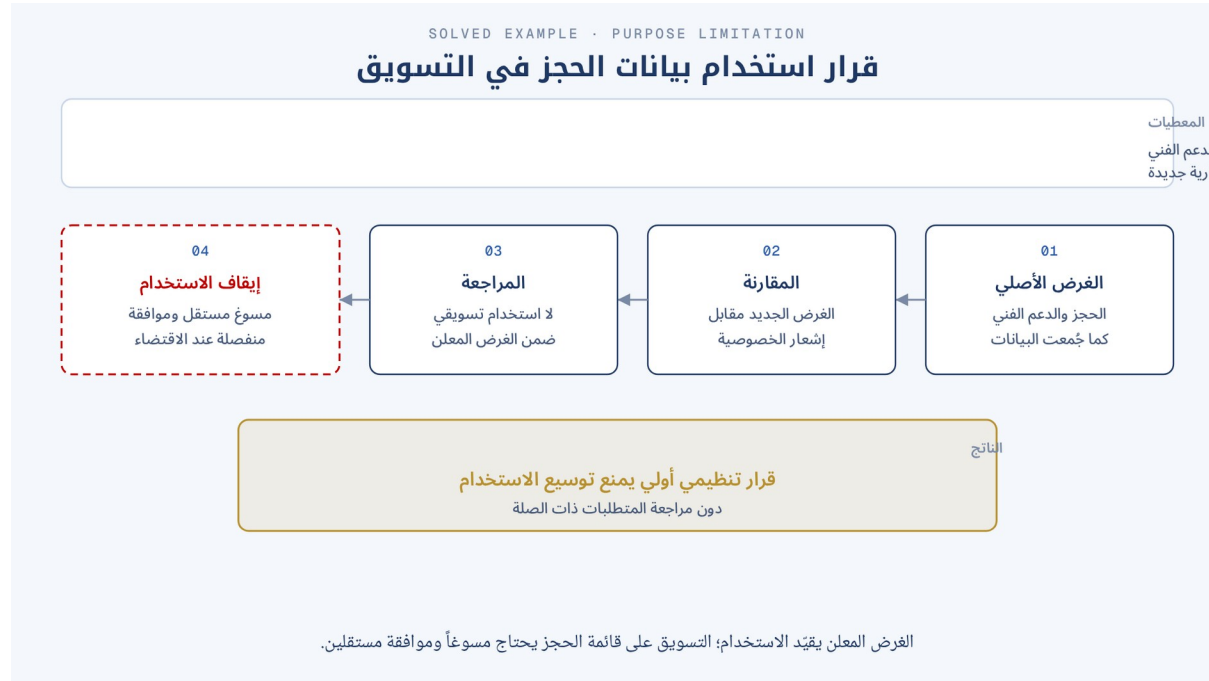
مقدم الطلب

المسؤول

الاعتماد

مستند تعليمي افتراضي، الأسماء والأرقام غير حقيقية

مثال محلول، قرار استخدام بيانات الحجز في التسويق



- المعطيات: تجمع الشركة الاسم ورقم الجوال والبريد الإلكتروني ونوع الخدمة لتقديم خدمة حجز تعليمية رقمية ودعم فني.
- وتقترح إدارة التسويق استخدام أرقام الجوال نفسها لإرسال عروض تجارية جديدة.
- الخطوات:
- النتائج: قرار تنظيمي أولي يمنع توسيع الاستخدام دون مراجعة المتطلبات ذات الصلة.

يوقف استخدام القائمة ويطلب مسوغاً مستقلاً وموافقة منفصلة عند الاقتضاء.

٤

يراجع عدم وجود استخدام تسويقي ضمن الغرض المعلن.

٣

يقارن الغرض الجديد بالغرض المعلن في إشعار الخصوصية.

٢

يحدد الغرض الأصلي، وهو الحجز والدعم الفني.

١



حقوق صاحب البيانات (Data Subject Rights)

- ◀ حقوق صاحب البيانات ترتبط بحماية الشخص الطبيعي في سياق معالجة بياناته الشخصية.
- ◀ وتوجه المؤسسة إلى تصميم قناة لاستقبال الطلبات وتوثيقها وإحالتها إلى المالك المختص، بدلاً من اتخاذ قرار قانوني فردي غير مخول.
- ◀ **الوظيفة:** تنظيم استقبال الطلبات والاستجابة المؤسسية لها.
- ◀ **المسؤوليات:** تحديد قناة الطلب، التحقق من الهوية عند اللزوم، توثيق المعالجة، إشراك المالك القانوني، حفظ قرار الاستجابة.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، GDPR.
- ◀ **الأجهزة أو الأدوات:** نموذج طلب، سجل طلبات، سياسة خصوصية، مسار تصعيد.
- ◀ وحدة البيانات أو المخرج: طلب موثق وقرار استجابة.
- ◀ **مثال:** توجه الشركة استفسار المستفيد عن معالجة بياناته إلى قناة الخصوصية وخدمة المستخدمين المعتمدة.

حقوق صاحب البيانات (Data Subject Rights) (الشكل)

SLIDE 38 · DATA SUBJECT RIGHTS

حقوق صاحب البيانات



الأجهزة والأدوات

- نموذج طلب
- سجل طلبات
- سياسة خصوصية
- مسار تصعيد

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- GDPR

الوظائف الرئيسية

- تنظيم استقبال الطلبات والاستجابة المؤسسية لها
- تحديد قناة الطلب
- التحقق من الهوية عند اللزوم
- توثيق المعالجة
- إشراك المالك القانوني

توجه الشركة استفسار المستفيد عن معالجة بياناته إلى قناة الخصوصية وخدمة المستخدمين المعتمدة

حقوق صاحب البيانات ترتبط بحماية الشخص الطبيعي في سياق معالجة بياناته الشخصية



- ◀ سياسة الخصوصية وثيقة تنظيمية تشرح تعامل الخدمة أو المؤسسة مع البيانات الشخصية، بما يرتبط بأغراض المعالجة والمسؤوليات.
- ◀ وتدعم الشفافية وتنظيم توقعات المستخدمين والعاملين.
- ◀ **الوظيفة:** توضيح الغرض والبيانات والأدوار وقنوات التواصل.
- ◀ **المسؤوليات:** وصف الغرض، تحديد الجهة المسؤولة، مراجعة الاتساق مع الممارسة، تحديث الوثيقة، إتاحتها للفئة المعنية.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، ISO/IEC 27001، ISO/IEC 27002، GDPR.
- ◀ **الأجهزة أو الأدوات:** وثيقة سياسة، سجل مراجعات، سجل معالجة بيانات.
- ◀ وحدة البيانات أو المخرج: سياسة خصوصية معتمدة ومراجعة.
- ◀ **مثال:** يطابق إشعار الخصوصية في خدمة حجز بيانات الاتصال والغرض وقناة الاستفسار الفعلية.



سياسة الخصوصية (Privacy Policy) (الشكل)

SLIDE 39 · PRIVACY POLICY

سياسة الخصوصية



سياسة الخصوصية

وثيقة تنظيمية تشرح تعامل الخدمة أو المؤسسة مع البيانات الشخصية، بما يرتبط بأغراض المعالجة والمسؤوليات. وتدعم الشفافية وتنظيم توقعات المستخدمين والعاملين.

سياسة خصوصية معتمدة ومراجعة.

الأجهزة والأدوات

- وثيقة سياسة
- سجل مراجعات
- سجل معالجة بيانات

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- GDPR
- ISO/IEC 27001
- ISO/IEC 27002

الوظائف الرئيسية

- توضيح الغرض والبيانات والأدوار وقنوات التواصل
- وصف الغرض
- تحديد الجهة المسؤولة
- مراجعة الاتساق مع الممارسة
- تحديث الوثيقة

يطابق إشعار الخصوصية في خدمة الحجز بيانات الاتصال والغرض وقناة الاستفسار الفعلية.

سياسة الخصوصية وثيقة تنظيمية تشرح تعامل الخدمة أو المؤسسة مع البيانات الشخصية، بما يرتبط بأغراض المعالجة والمسؤوليات.



التصعيد القانوني (Legal Escalation)



- ◀ التصعيد القانوني هو إحالة واقعة أو قرار ذي أثر نظامي محتمل إلى الشؤون القانونية أو الجهة المختصة وفق المسار المعتمد.
- ◀ وظيفته ضبط المسؤولية ومنع اتخاذ قرارات قانونية حساسة من غير المخولين.
- ◀ **الوظيفة:** إحالة الوقائع ذات الأثر القانوني المحتمل.
- ◀ **المسؤوليات:** رصد الواقعة، توثيق الوقائع، تحديد المالك، إحالة الحالة، متابعة القرار والتوصيات.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، نظام مكافحة جرائم المعلوماتية، ISO/IEC 27001.
- ◀ **الأجهزة أو الأدوات:** نموذج تصعيد، سجل بلاغ، سجل قرارات، قناة تواصل معتمدة.
- ◀ وحدة البيانات أو المخرج: طلب رأي أو قرار تصعيد موثق.
- ◀ **مثال:** تحليل الشركة مشاركة بيانات قد تكون غير منضبطة إلى وحدة الخصوصية والإدارة القانونية.



التصعيد القانوني (Legal Escalation) (الشكل)

SLIDE 40 · LEGAL ESCALATION

التصعيد القانوني

التصعيد القانوني هو إحالة واقعة أو قرار ذي أثر نظامي محتمل إلى الشؤون القانونية أو الجهة المختصة وفق المسار المعتمد. وظيفته ضبط المسؤولية ومنع اتخاذ قرارات قانونية حساسة من غير المخولين.



الأجهزة والأدوات

- نموذج تصعيد
- سجل بلاغ
- سجل قرارات
- قناة تواصل معتمدة

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- نظام مكافحة جرائم المعلوماتية
- ISO/IEC 27001

الوظائف الرئيسية

- إحالة الوقائع ذات الأثر القانوني المحتمل
- رصد الواقعة
- توثيق الوقائع
- تحديد المالك
- إحالة الحالة

تحيل الشركة مشاركة بيانات قد تكون غير منضبطة إلى وحدة الخصوصية والإدارة القانونية

التصعيد القانوني هو إحالة واقعة أو قرار ذي أثر نظامي محتمل إلى الشؤون القانونية أو الجهة المختصة وفق المسار المعتمد.



الاستشارة القانونية (Legal Consultation)



- ◀ الاستشارة القانونية هي طلب تحليل من مختص قانوني حول انطباق نظام أو التزام أو أثر واقعة محددة.
- ◀ وهي تفصل بين التوعية التعليمية والقرار القانوني الملزم في الحالات الفعلية أو المعقدة.
- ◀ **الوظيفة:** دعم القرار التنظيمي بمراجعة مختصة.
- ◀ **المسؤوليات:** تقديم وقائع دقيقة، عدم إخفاء معلومات جوهرية، حفظ السرية، توثيق السؤال والرد، تنفيذ التوصيات ضمن الصلاحية.
- ◀ **البروتوكولات والمعايير:** الأنظمة واللوائح ذات الصلة، سياسات المؤسسة، ISO/IEC 27001.
- ◀ **الأجهزة أو الأدوات:** نموذج استشارة، سجل قرارات، ملف وقائع، سجل متابعة.
- ◀ وحدة البيانات أو المخرج: توجيه قانوني موثق داخلياً.
- ◀ **مثال:** تطلب الشركة مراجعة لمسار نقل بيانات إلى جهة خارج المملكة قبل تنفيذ التغيير.

الاستشارة القانونية (Legal Consultation) (الشكل)

SLIDE 41 · LEGAL CONSULTATION

الاستشارة القانونية

الاستشارة القانونية هي طلب تحليل من مختص قانوني حول انطباق نظام أو التزام أو أثر واقعة محددة. وهي تفصل بين التوعية التعليمية والقرار القانوني الملزم في الحالات الفعلية أو المعقدة.



الأجهزة والأدوات

- نموذج استشارة
- سجل قرارات
- ملف وقائع
- سجل متابعة

البروتوكولات والمعايير

- الأنظمة واللوائح ذات الصلة
- سياسات المؤسسة
- ISO/IEC 27001

تطلب الشركة مراجعة لمسار نقل بيانات إلى جهة خارج المملكة قبل تنفيذ التغيير

الوظائف الرئيسية

- دعم القرار التنظيمي بمراجعة مختصة
- تقديم وقائع دقيقة
- عدم إخفاء معلومات جوهرية
- حفظ السرية
- توثيق السؤال والرد

الاستشارة القانونية هي طلب تحليل من مختص قانوني حول انطباق نظام أو التزام أو أثر واقعة محددة



الفرق بين مخالفة السياسة والمخالفة النظامية

- ◀ السياسة وثيقة داخلية تنظم السلوك والتنفيذ، بينما قد تكون المخالفة خرقاً للسياسة أو للنظام أو لكليهما بحسب الوقائع.
- ◀ يبدأ التحليل بتحديد الفعل والبيانات المتأثرة والسجل المرتبط، ثم يحدد المسار المؤسسي المناسب.
- ◀ **الوظيفة:** منع التوصيف القانوني المتسرع للواقعة.
- ◀ **المسؤوليات:** قراءة السياسة، تحديد الفعل والبيانات، فحص النظام ذي الصلة، توثيق الوقائع، تصعيد التكييف القانوني للمختص.
- ◀ **البروتوكولات والمعايير:** سياسات المؤسسة، نظام حماية البيانات الشخصية، نظام مكافحة جرائم المعلوماتية، ISO/IEC 27001.
- ◀ **الأجهزة أو الأدوات:** سياسة، سجل مخالفة، نموذج تحقيق داخلي، سجل إجراء تصحيحي.
- ◀ وحدة البيانات أو المخرج: تصنيف أولي وخطة متابعة.
- ◀ **مثال:** استخدام بريد شخصي لإرسال ملف عمل مخالفة داخلية تستلزم فحص أثرها عند وجود بيانات شخصية.



- ◀ تلقى مشرف الدعم في الشركة اتصالاً يطلب سجل طلبات وعناوين عميل، وادعى المتصل وجود خلاف تجاري شخصي وقدم بيانات جزئية عن العميل.
- ◀ حدد نوع الطلب، ثم اكتب ثلاثة إجراءات تنظيمية أولية.
- ◀ راع حماية البيانات الشخصية، وعدم الإفصاح المباشر، وتوثيق الطلب، ومسار التصعيد إلى الجهة المختصة داخل المؤسسة.



- ◀ يصنف الطلب بوصفه طلب إفصاح خارجي عن بيانات شخصية لا يمنح الاتصال الهاتفي وحده صلاحية لتنفيذه.
- ◀ أولاً، يرفض مشرف الدعم الإفصاح المباشر عن سجل الطلبات والعناوين.
- ◀ ثانياً، يوثق بيانات الطلب ووسيلة الاتصال والوقائع المتاحة.
- ◀ ثالثاً، يصعد الطلب إلى مسؤول الخصوصية أو الإدارة القانونية عبر القناة المعتمدة للنظر في أي مسوغ نظامي أو طلب رسمي.

بعد إتمام الفصل، قيّم وضوح المستندات والأنشطة في هذا الفصل عبر أداة التعليق في المنصة.

اذكر مفهوماً واحداً أصبح أوضح لك، ونقطة واحدة تحتاج مثالاً إضافياً، واقتراحاً واحداً لتحسين تسلسل التعلم. لا تدرج بيانات شخصية أو تفاصيل عن وقائع عمل فعلية في تعليقك.



مرحلة المشروع التراكمي الثانية





أثر القانون على التصميم التنظيمي

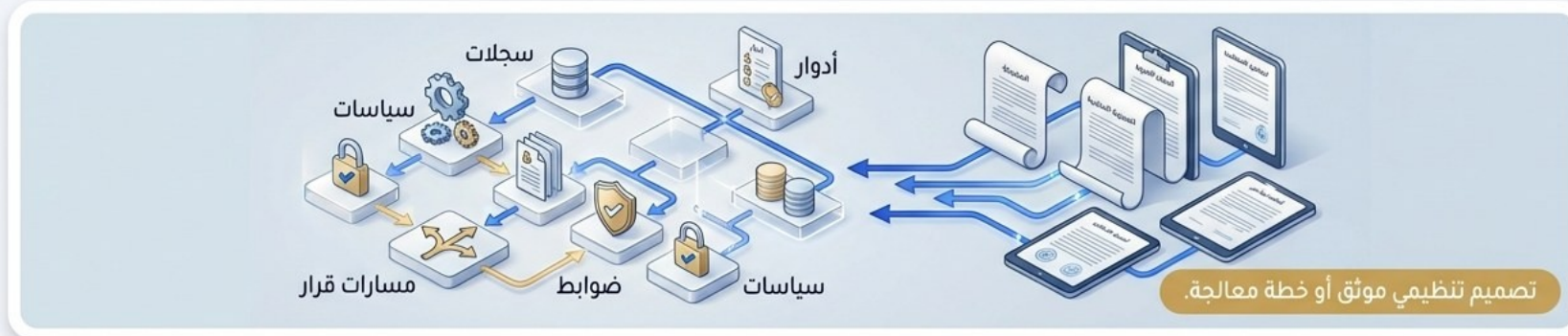
- ◀ أثر القانون على التصميم التنظيمي هو ترجمة المتطلبات القانونية والتنظيمية إلى أدوار وسجلات وسياسات وضوابط ومسارات قرار داخل المؤسسة.
- ◀ ويساعد هذا التوجه على دمج الامتثال في تصميم الخدمة بدلاً من معالجته بعد ظهور المشكلة.
- ◀ **الوظيفة:** تحويل المتطلبات إلى ممارسات تنظيمية قابلة للمتابعة.
- ◀ **المسؤوليات:** تحديد المتطلبات، تعيين الملاك، بناء السجلات والأدلة، تصميم الضوابط، متابعة التحسين.
- ◀ **البروتوكولات والمعايير:** نظام حماية البيانات الشخصية، ISO/IEC 27001، ISO/IEC 27002، NIST CSF 2.0، ECC 2-2024.
- ◀ **الأجهزة أو الأدوات:** مصفوفة متطلبات، سجل معالجة، مصفوفة مسؤوليات، سياسة خصوصية، دليل امتثال.
- ◀ وحدة البيانات أو المخرج: تصميم تنظيمي موثق أو خطة معالجة.
- ◀ **مثال:** تربط الشركة كل نوع بيانات بغرض ومالك وفترة احتفاظ ومسار بلاغ.



أثر القانون على التصميم التنظيمي (الشكل)

SLIDE 45 • ELEMENT

أثر القانون على التصميم التنظيمي



الأجهزة والأدوات

- مصفوفة متطلبات
- سجل معالجة
- مصفوفة مسؤوليات
- سياسة خصوصية
- دليل امتثال

البروتوكولات والمعايير

- نظام حماية البيانات الشخصية
- ISO/IEC 27001
- ISO/IEC 27002
- NIST CSF 2.0
- ECC 2-2024

الوظائف الرئيسية

- تحويل المتطلبات إلى ممارسات تنظيمية
- قابلة للمتابعة
- تحديد المتطلبات
- تعيين الملاك
- بناء السجلات والأدلة
- تصميم الضوابط

تربط الشركة كل نوع بيانات بغرض ومالك وفترة احتفاظ ومسار بلاغ.

أثر القانون على التصميم التنظيمي هو ترجمة المتطلبات القانونية والتنظيمية إلى أدوار وسجلات وسياسات وضوابط ومسارات قرار داخل المؤسسة.



مقارنة مفاهيم الخصوصية التنظيمية

البعد	النظام السعودي لحماية البيانات الشخصية	اللائحة العامة لحماية البيانات GDPR	الأثر التعليمي على المؤسسة
موضوع التنظيم	حماية البيانات الشخصية وتنظيم معالجتها	حماية الأشخاص الطبيعيين عند معالجة بياناتهم الشخصية	توثيق المؤسسة البيانات والغرض والمالك
جهة التحكم	تحدد الأدوار والمسؤوليات التنظيمية	تحدد أغراض المعالجة ووسائلها	تعين المؤسسة مالك المعالجة
سجل المعالجة	يدعم تنظيم البيانات والغرض والمسؤوليات	يدعم توثيق المعالجة والأدوار	يراجع السجل عند تغيير الخدمة
نطاق المقارنة	إطار سعودي تنظيمي	إطار أوروبي تنظيمي	لا يستنتج الانطباق الفعلي من المقارنة وحدها

المقارنة بين الإطارين تعليمية ومفهومية، وتحتاج الوقائع الفعلية إلى مراجعة مختصة لتحديد النظام الواجب التطبيق.



مصفوفة مسؤوليات معالجة واقعة خصوصية

الواقعة	مسؤولية الموظف	مسؤولية المنظمة	الإجراء الوقائي
إرسال ملف درجات إلى بريد شخصي	الالتزام بالقناة المعتمدة والإبلاغ	توفير قنوات آمنة ومراجعة الصلاحيات	توعية موجهة وضبط التصدير
استخدام بيانات الحجز في التسويق	عدم توسيع الاستخدام دون مسوغ	مراجعة الغرض وسجل المعالجة	موافقة مستقلة عند الاقتضاء
مشاركة بيانات مع طرف خارجي	التحقق من الصلاحية والتصعيد	تنظيم الإفصاح والتعاقد والسجلات	قناة مشاركة معتمدة
اكتشاف وصول غير مصرح	عدم العبث بالسجل والإبلاغ	احتواء الواقعة وحفظ الأدلة	مراجعة الصلاحيات وسجل الوصول



✓ **يُميز** الفصل بين حماية البيانات الشخصية ومكافحة الجرائم الإلكترونية ومخالفة السياسة الداخلية، وهو ما يحقق الهدف الثاني.

✓ **يشرح** الإطار القانوني الحقوق والالتزامات ومسارات التعامل مع الوقائع، وهو ما يحقق الهدف الأول.

✓ **يوضح** تحليل بلاغ كشف الدرجات مسؤولية الموظف والمنظمة، وهو ما يحقق الهدف الرابع.

✓ **تقارن** الجداول بين مفاهيم النظام السعودي و GDPR على مستوى الغرض والمعالجة والسجلات والمسؤوليات، وهو ما يحقق الهدف الثالث.

✓ **تدعم** نماذج السجل والإشعار والبلاغ اقتراح استجابة تنظيمية أولية موثقة، وهو ما يحقق الهدف الخامس.



- ◀ الهيئة السعودية للبيانات والذكاء الاصطناعي. دليل نظام حماية البيانات الشخصية لجهات التحكم والمعالجة.
- ◀ المملكة العربية السعودية. هيئة الخبراء بمجلس الوزراء. نظام مكافحة جرائم المعلوماتية. المرسوم الملكي رقم (م/17).
- ▶ European Parliament and Council. (2016). Regulation (EU) 2016/679, General Data Protection Regulation.
- ▶ International Organization for Standardization. (2022). ISO/IEC 27001:2022.
- ▶ International Organization for Standardization. (2022). ISO/IEC 27002:2022.
- ▶ Pascoe, C., Quinn, S., & Scarfone, K. (2024). The NIST Cybersecurity Framework (CSF) 2.0.
- ◀ الهيئة الوطنية للأمن السيبراني. (2024). الضوابط **الأساسية للأمن السيبراني (ECC 2-2024)**.
- ▶ Whitman, M. E., & Mattord, H. J. (2022). Principles of Information Security (7th ed.).



معهد البحوث والخدمات الاستشارية
Institute of Research and Consulting Services

شكراً لكم

معهد البحوث والخدمات الاستشارية – جامعة جازان